Security Hands-On pentest a Damn Vulnerable App

Esilv 2025

arnaud.nauwynck@gmail.com

Lot of dva "Damn Vulnerable Apps"

Example
https://jwljoy.medium.com/damn-vulnerable-applications-c4e286832147

Awesome Damn Vulnerable Applications

Jewel Joy · Follow
2 min read · Jul 28, 2019

90



This list is a compilation of the various types of applications which is intentionally made insecure and famously known as "Damn Vulnerable". These application are made to help security enthusiasts learn / sharpen their skills in the field of information security and penetration testing.

Disclaimer : The projects and its credit goes to the creators of these amazing projects

. . .

Web Applications

- Web Application : https://github.com/ethicalhack3r/DVWA
- Word Press : https://github.com/vianasw/dvwps
- Node JS : https://github.com/appsecco/dvna
- Web Sockets : https://hub.docker.com/r/tssoffsec/dvws/
- Python : https://github.com/anxolerd/dvpwa
- Ruby on Rails : https://github.com/guilleiguaran/dvra
- Ruby on Rails : https://git.logicalhacking.com/BrowserSecurity/DVGM
- GraphQL : https://github.com/dolevf/Damn-Vulnerable-GraphQL-Application

Web Service Applications

- Web Service : https://github.com/snoopysecurity/dvws
- API : https://github.com/payatu/Tiredful-API/
- C# API Only : https://github.com/appsecco/dvcsharp-api

Source Code

- Source Code : https://github.com/h4x0r101/Damn-Vulnerable-Source-Code

Thick Client

- Thick Client Application : https://github.com/secvulture/dvta
- Java EE : https://github.com/appsecco/dvja

Mobile Application

- iOS Swift : https://github.com/prateek147/DVIA-v2
- iOS: https://github.com/prateek147/DVIA
- Android : https://github.com/payatu/diva-android
- Hybrid Mobile Application : https://github.com/logicalhacking/DVHMA

Crypto & Block Chain

- Crypto Wallet : https://gitlab.com/badbounty/dvcw
- Wallet : https://github.com/genecyber/Damn-Vulnerable-Wallet-App
- Block Chain : https://github.com/subashsn/dvba

OS Related

- Linux : https://www.vulnhub.com/series/damn-vulnerable-linux-dvl,1/
- Windows : https://sourceforge.net/projects/dawn-vulnerability-windows/
- Device Driver : https://github.com/pwk4m1/Damn_Vulnerable_Device_Driver

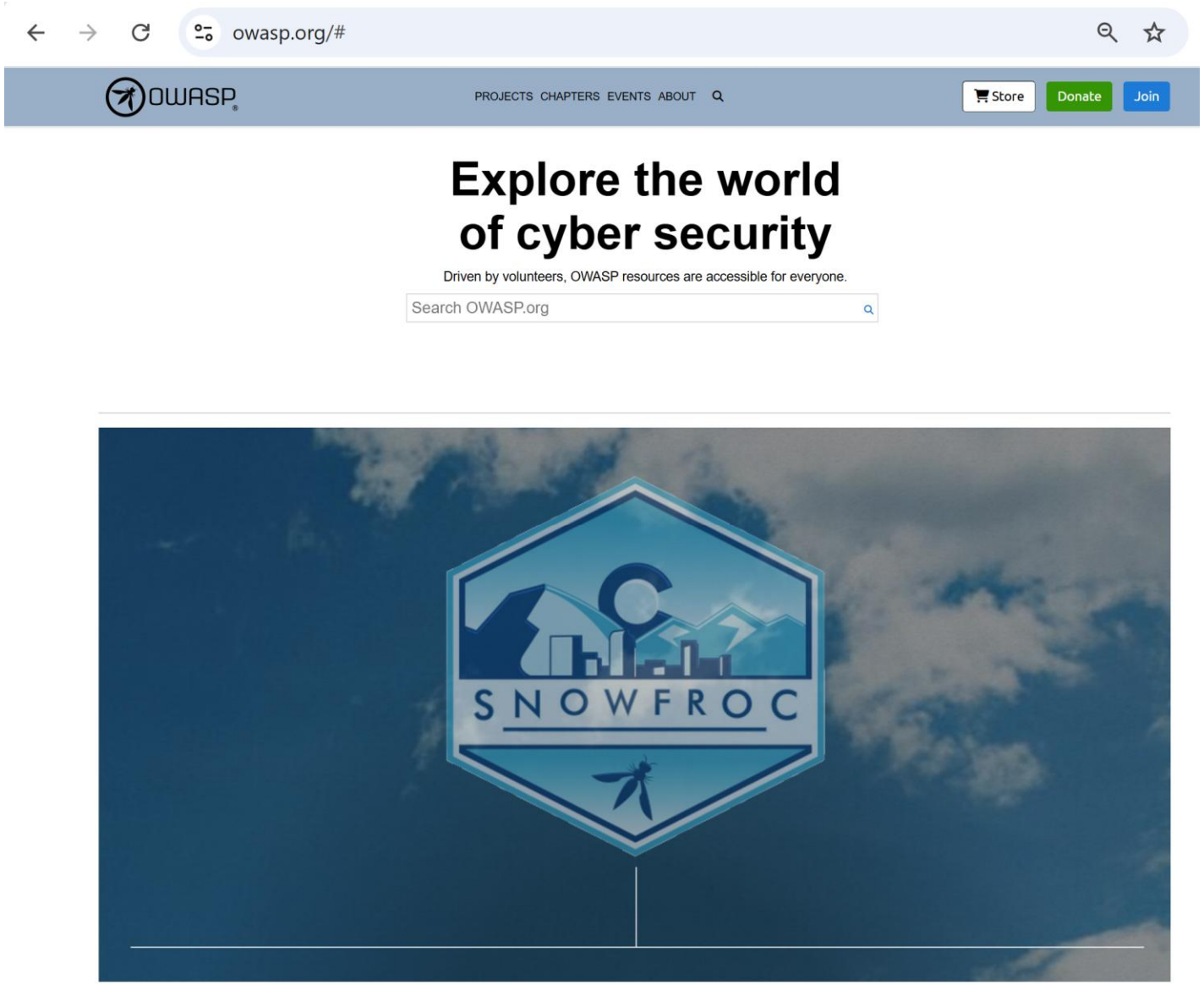
Cloud Infrastructure

- Cloud Application : https://github.com/m6a-UdS/dvca
- Cloud App (AWS) : https://github.com/RhinoSecurityLabs/cloudgoat
- Function-as-a-service (AWS Lambda) : https://github.com/we45/DVFaaS-Damn-Vulnerable-Functions-as-a-Service
- Serverless Application : https://github.com/OWASP/DVSA
- Functions as a Service : https://github.com/we45/DVFaaS-Damn-Vulnerable-Functions-as-a-Service

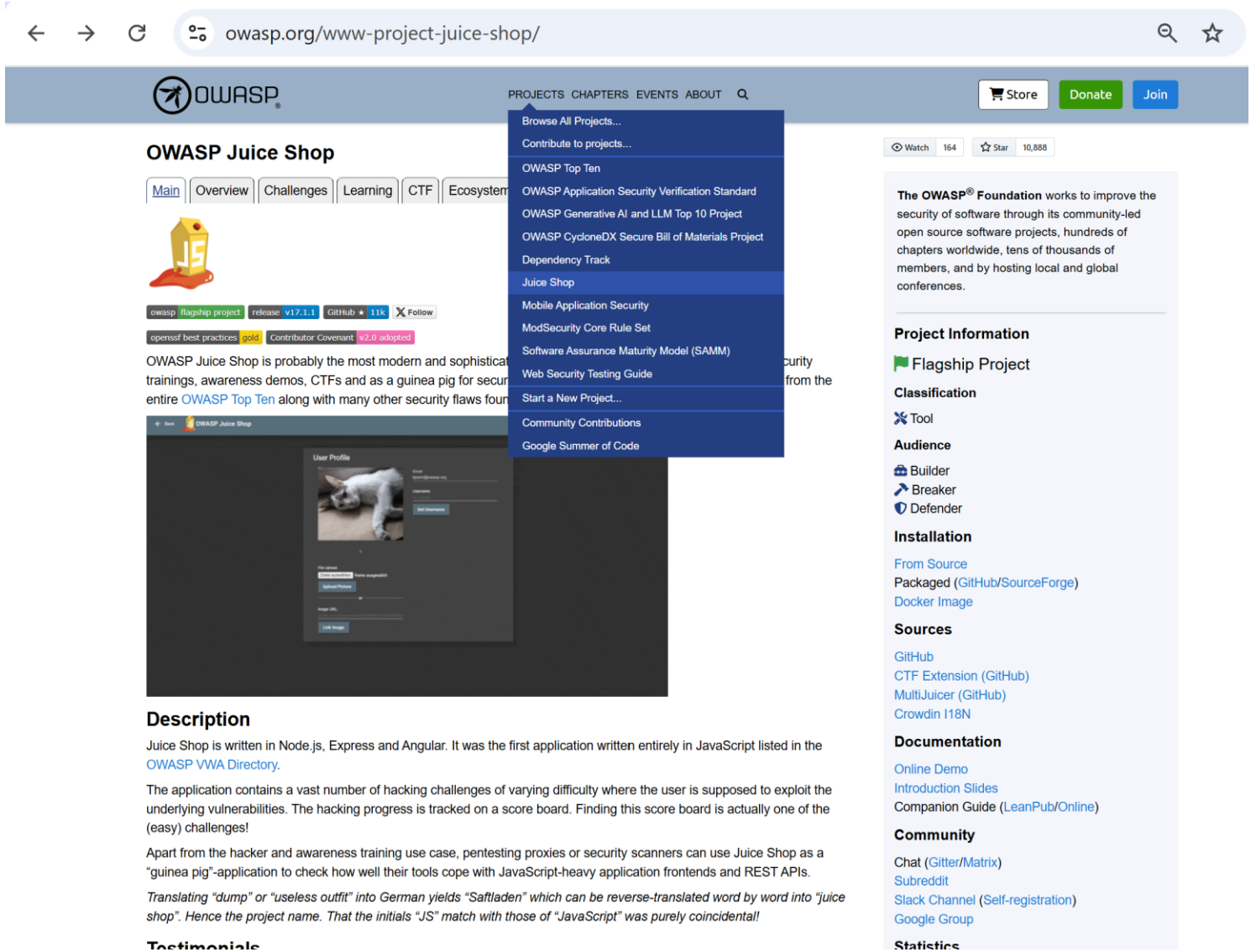
IoT and Hardware

- IoT : https://github.com/Vulcainreo/DVID
- Router : https://github.com/praetorian-code/DVRF
- Safe : https://insinuator.net/2016/01/damn-vulnerable-safe/
- SCADA : https://www.slideshare.net/phdays/damn-vulnerable-chemical-process
- PI : https://whitedome.com.au/re4son/sticky-fingers-dv-pi/
- SS7 Network: https://www.blackhat.com/asia-17/arsenal.html#damn-vulnerable-ss7-network
- VoIP : https://www.vulnhub.com/entry/hacklab-vulnvoip,40/

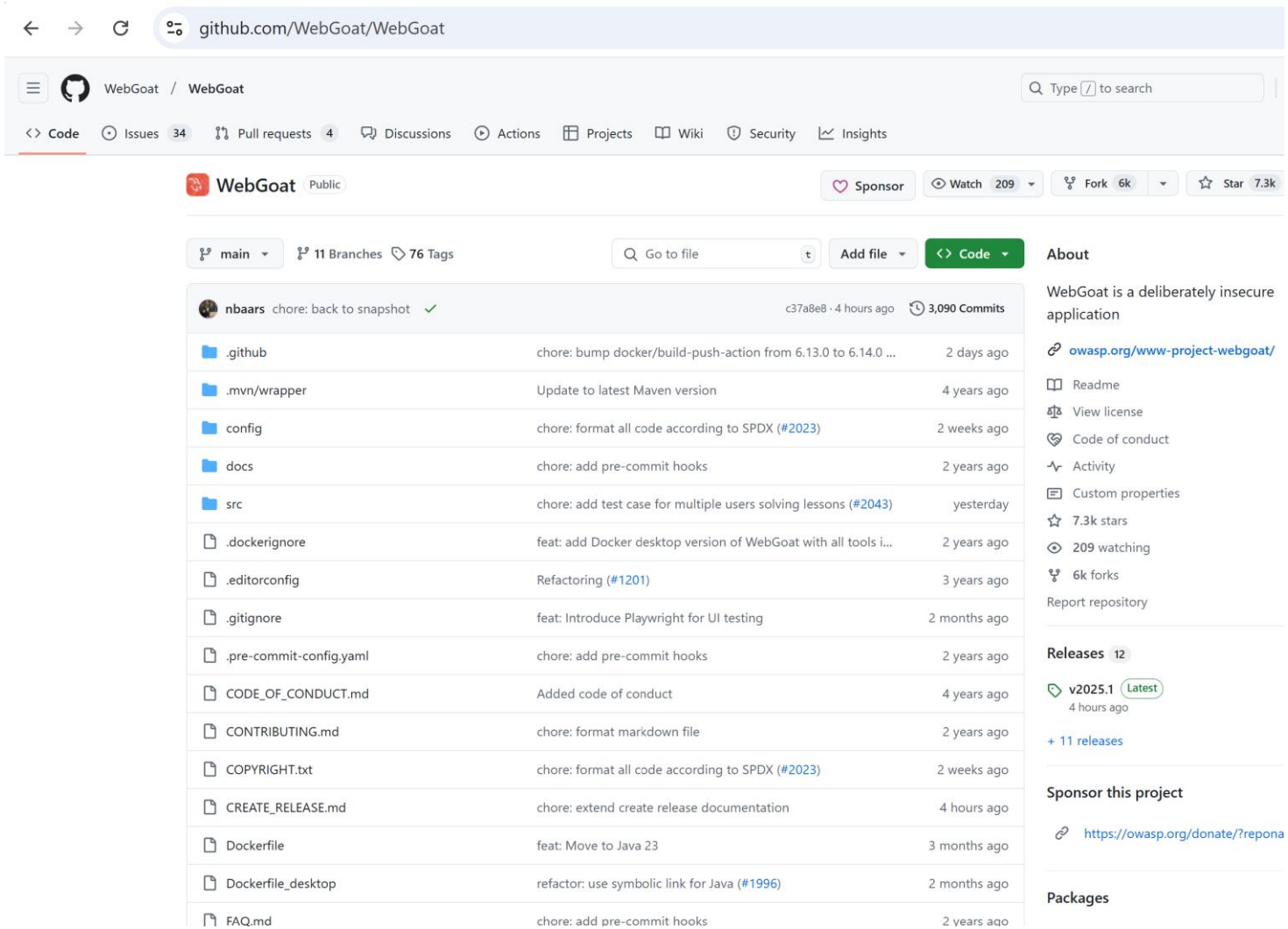
https://owasp.org



Juice Shop … vulnerable app (in node.js / express)



WebGoat ... vulnerable app in java https://github.com/WebGoat/WebGoat



Download/Compile/Launch WebGoat App

```
docker run -it \
    -p 127.0.0.1:8080:8080 \
    -p 127.0.0.1:9090:9090 \
    webgoat/webgoat
```

Installation instructions:

For more details check the Contribution guide

1. Run using Docker

Already have a browser and ZAP and/or Burp installed on your machine in this case you can run the WebGoat image directly using Docker.

Every release is also published on DockerHub.

```
docker run -it -p 127.0.0.1:8080:8080 -p 127.0.0.1:9090:9090 webgoat/webgoat
```

or ..

```
git clone https://github.com/WebGoat/WebGoat
cd WebGoat
mvn package
mvn spring-boot:run
```

or ..

download zip from github code
open as IntelliJ IDEA project

or ..

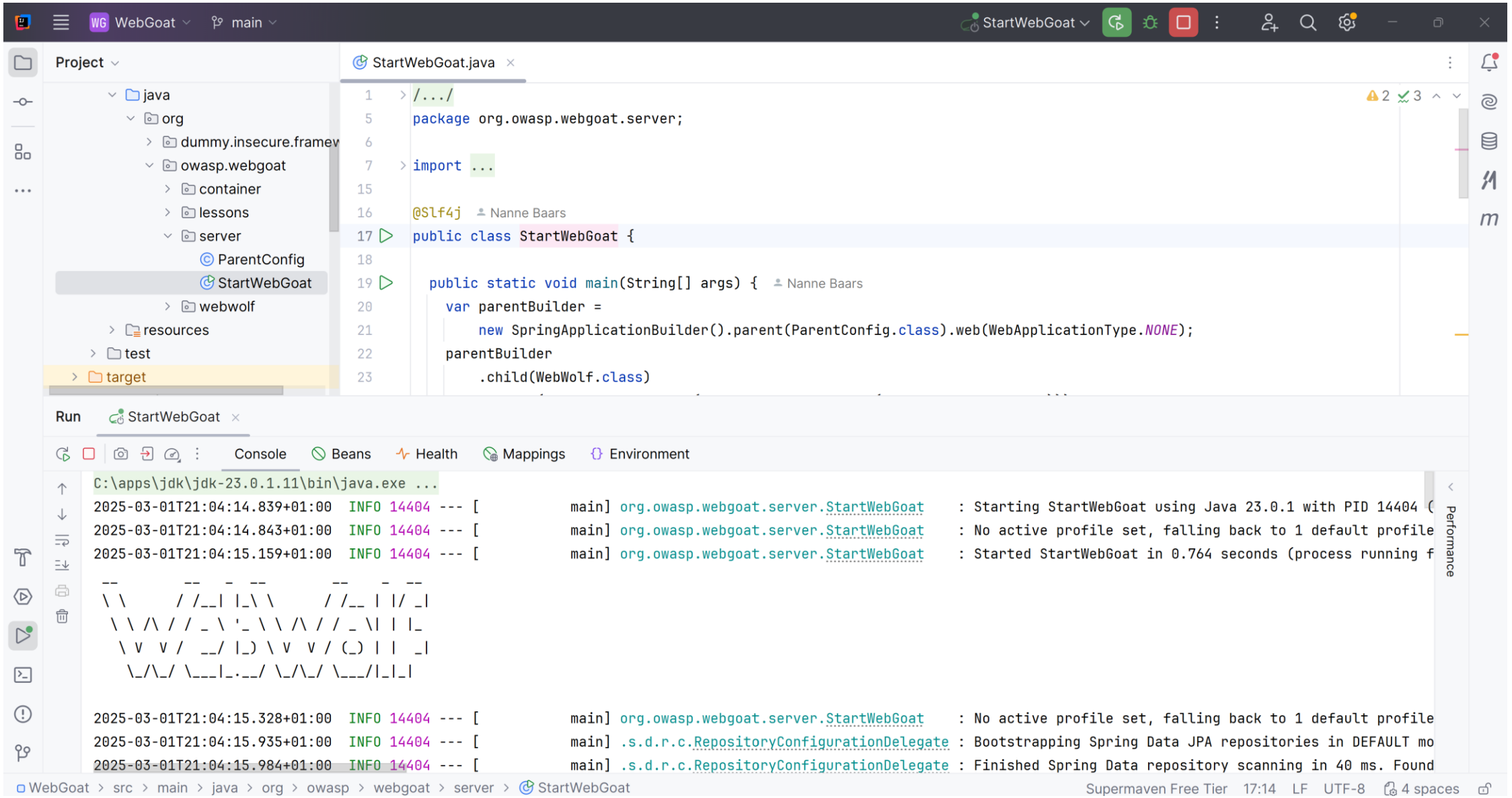
download pre-compiled jar
launch

3. Standalone

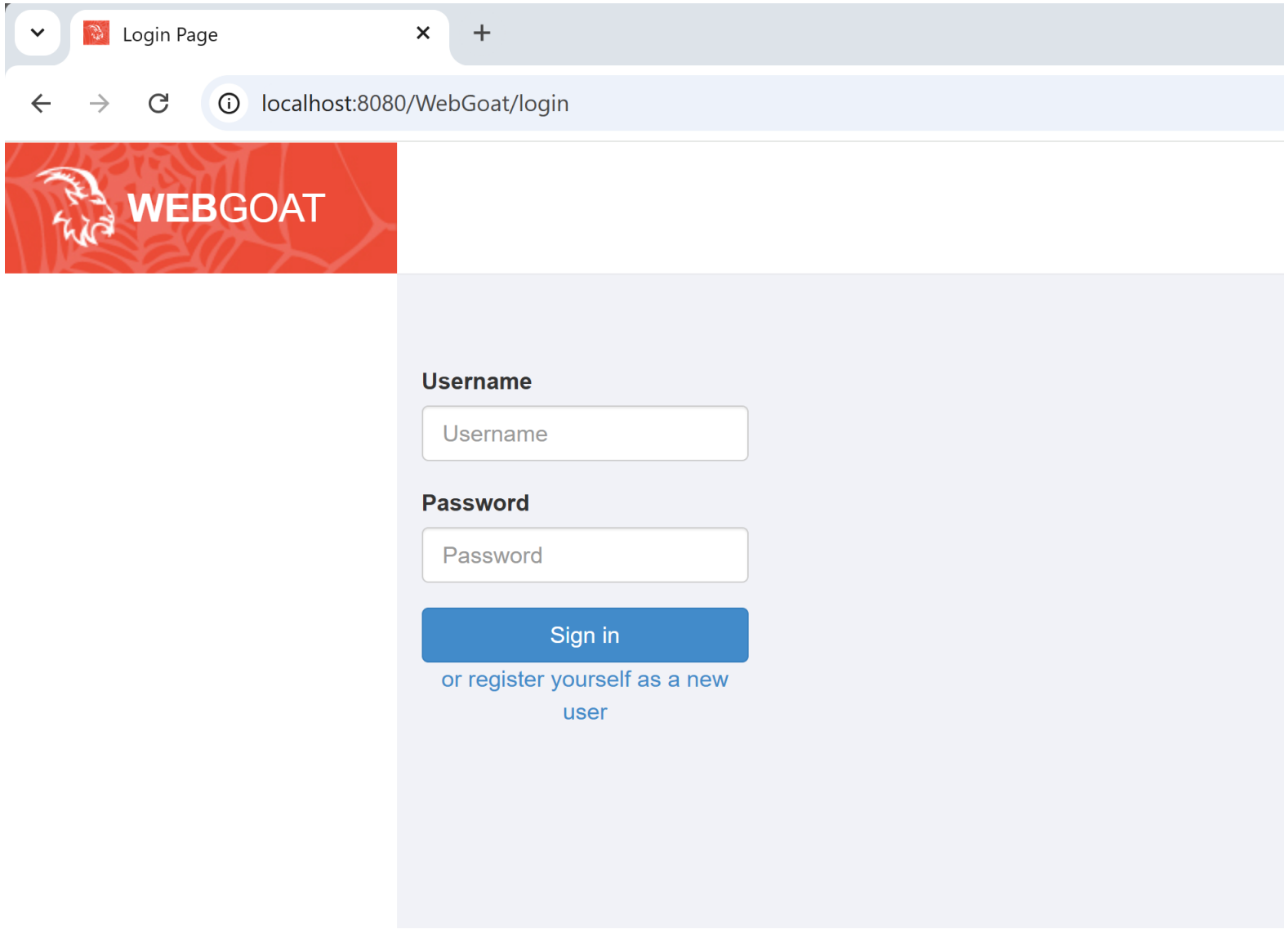
Download the latest WebGoat release from https://github.com/WebGoat/WebGoat/releases

```
export TZ=Europe/Amsterdam # or your timezone
java -Dfile.encoding=UTF-8 -jar webgoat-2023.8.jar
```

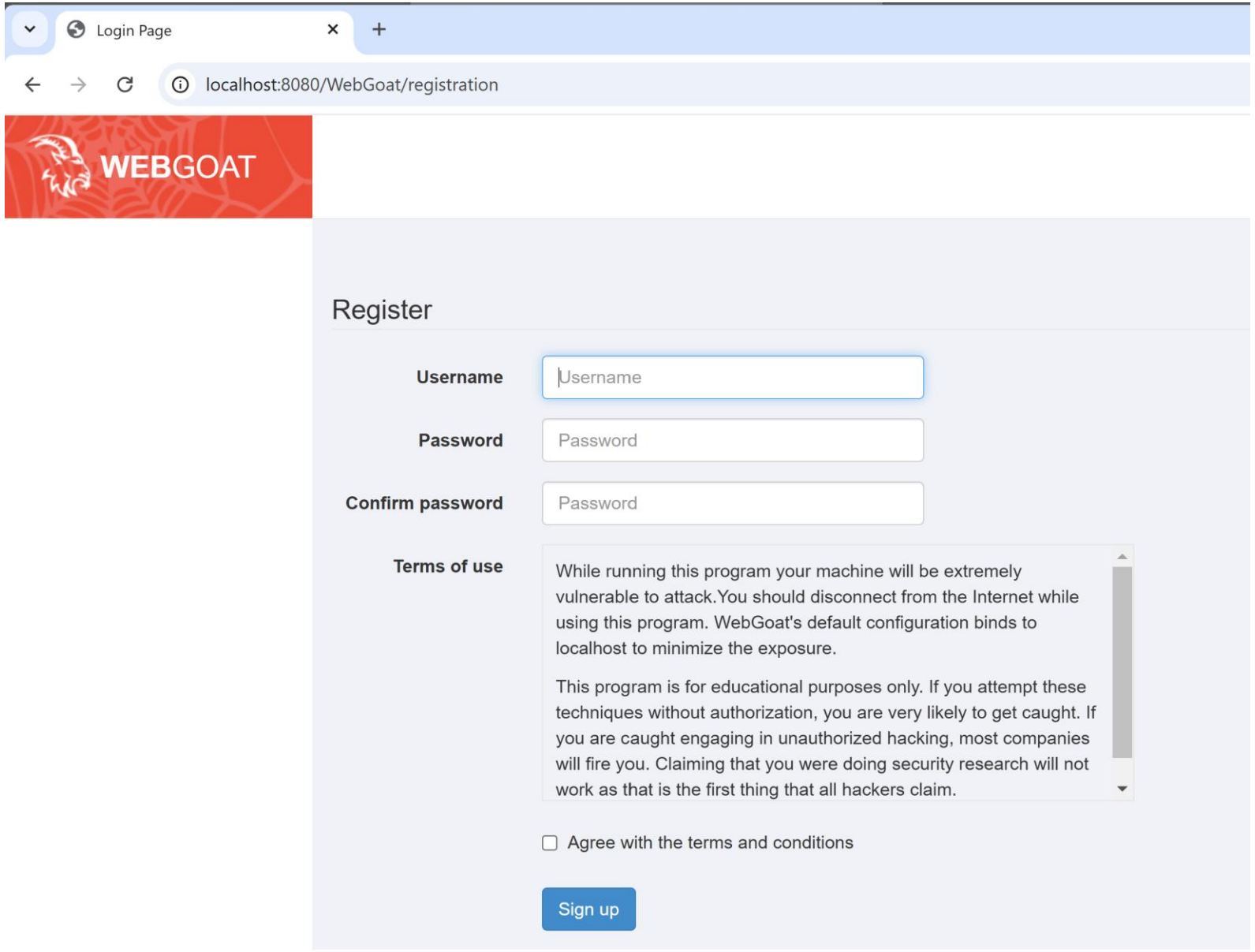
Launching from IDE



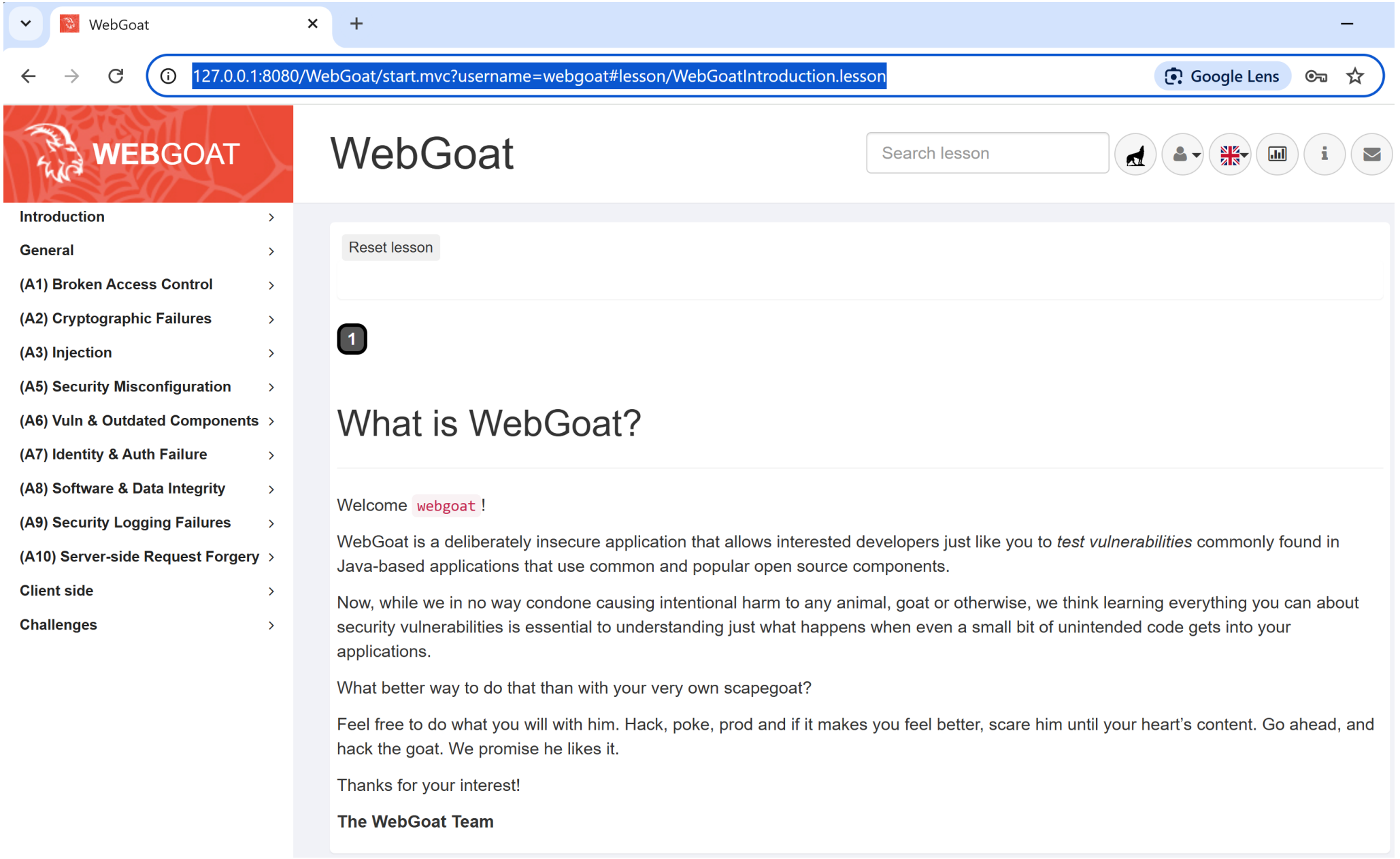
open http://localhost:8080/WebGoat/login



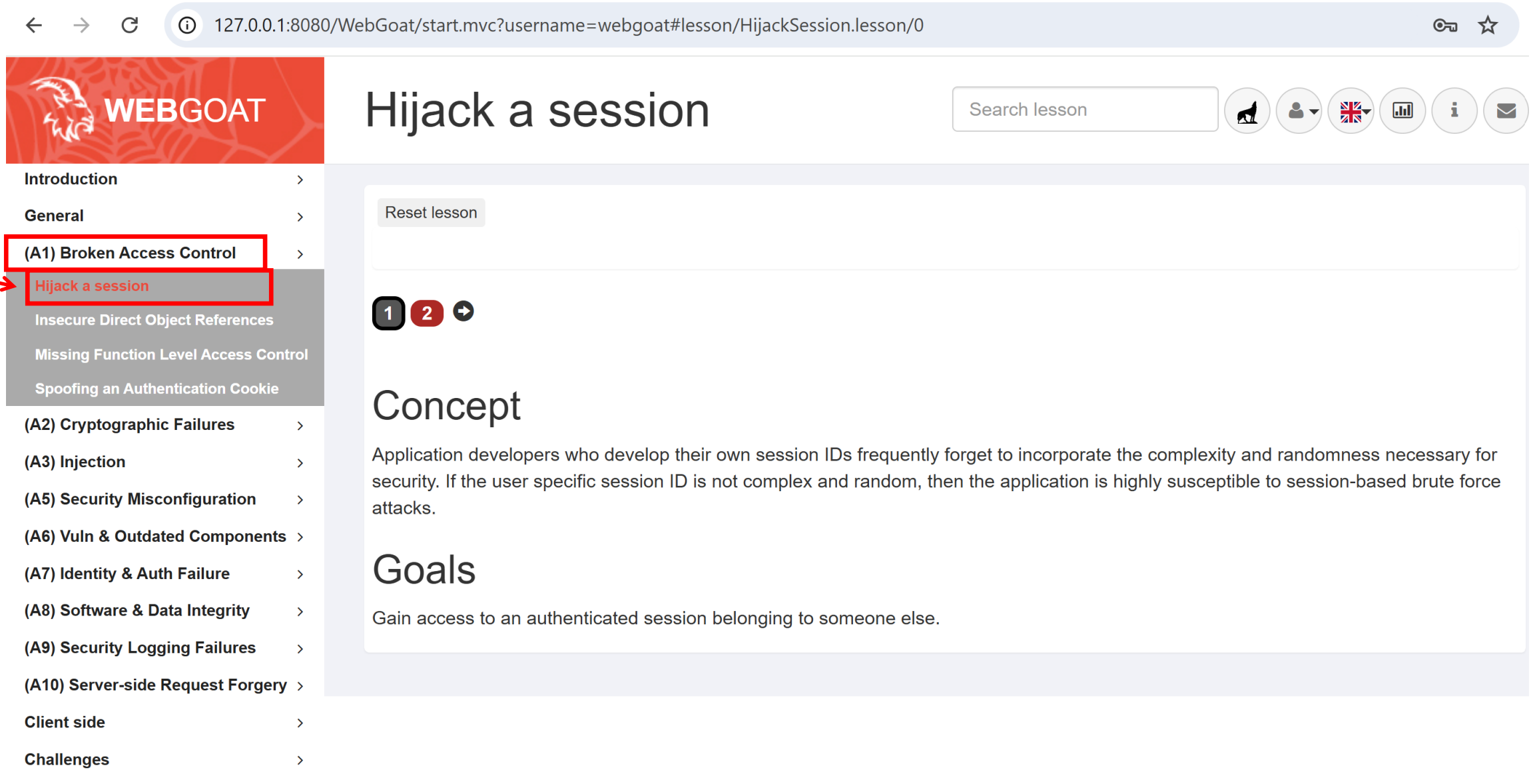
register a login/password



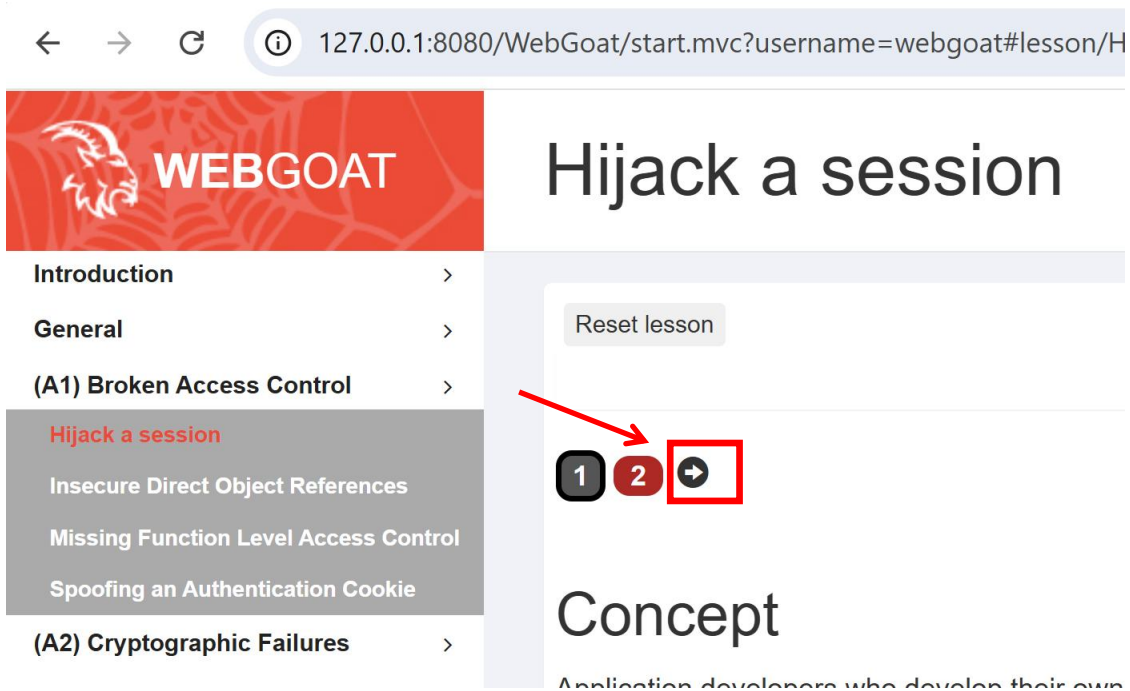
Browse lesson(s)



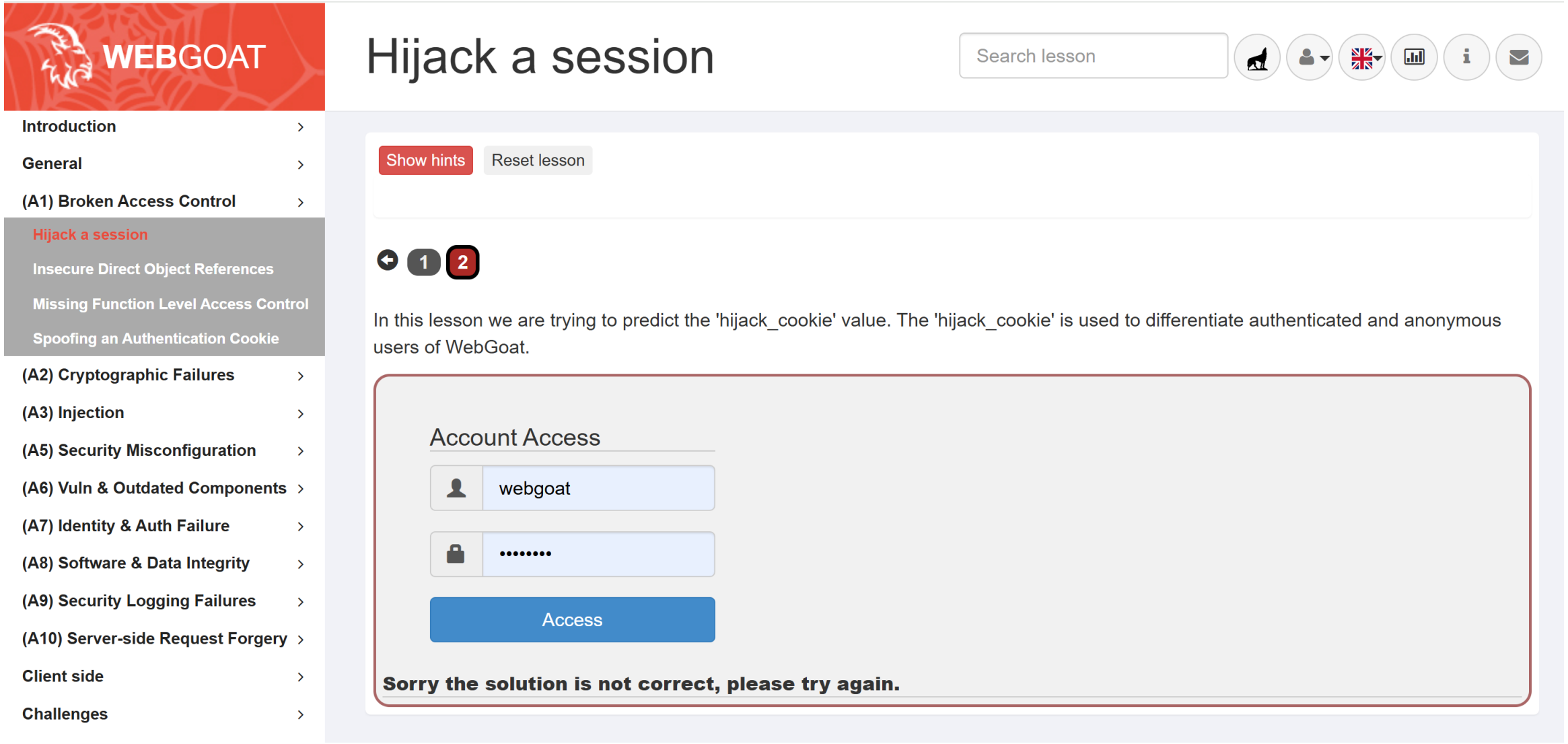
Lesson (A1) - Broken Access Control
Hijack a session



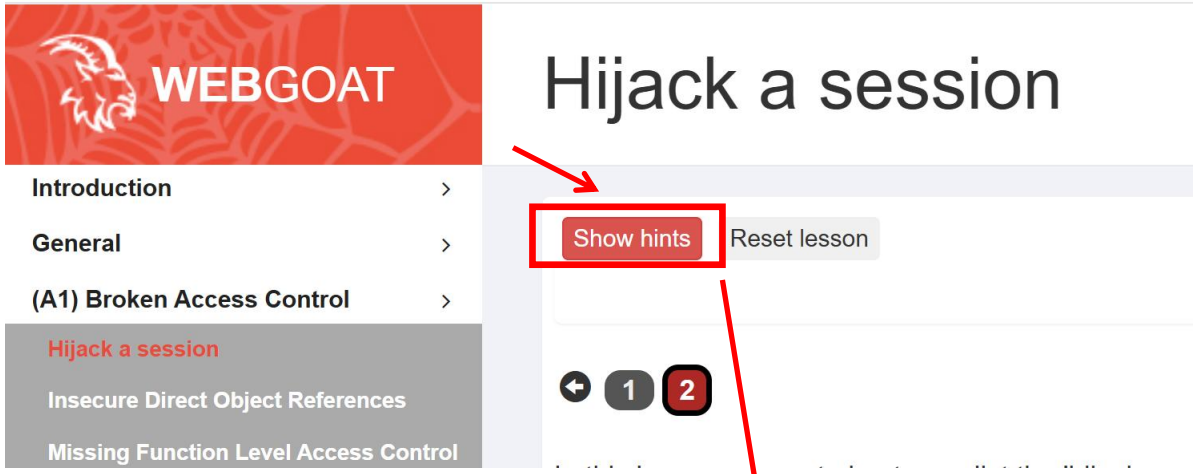
Page 1 / Page 2 / …

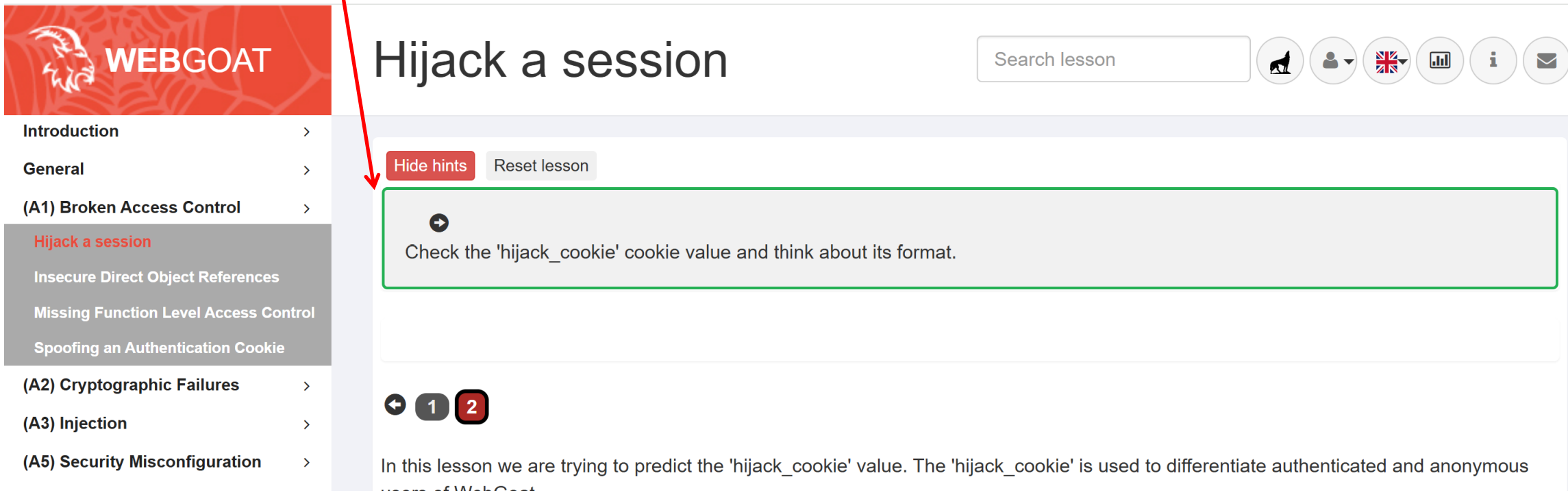

127.0.0.1:8080/WebGoat/start.mvc?username=webgoat#lesson/H
WEBGOAT
Hijack a session
Introduction
General
(A1) Broken Access Control
Hijack a session
Insecure Direct Object References
Missing Function Level Access Control
Spoofing an Authentication Cookie
(A2) Cryptographic Failures
Reset lesson
1
2
Concept

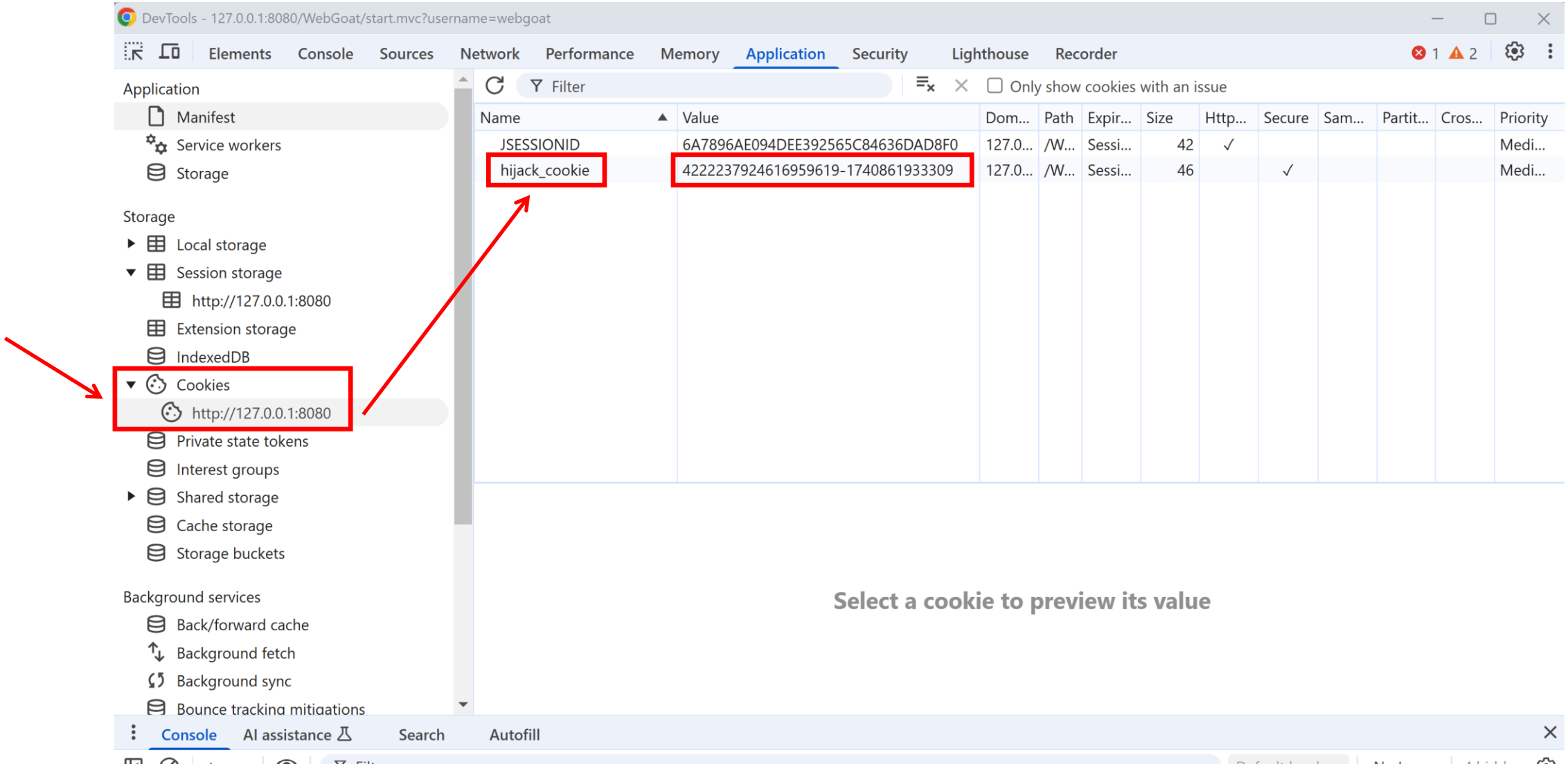
Hijack Session - Step 2



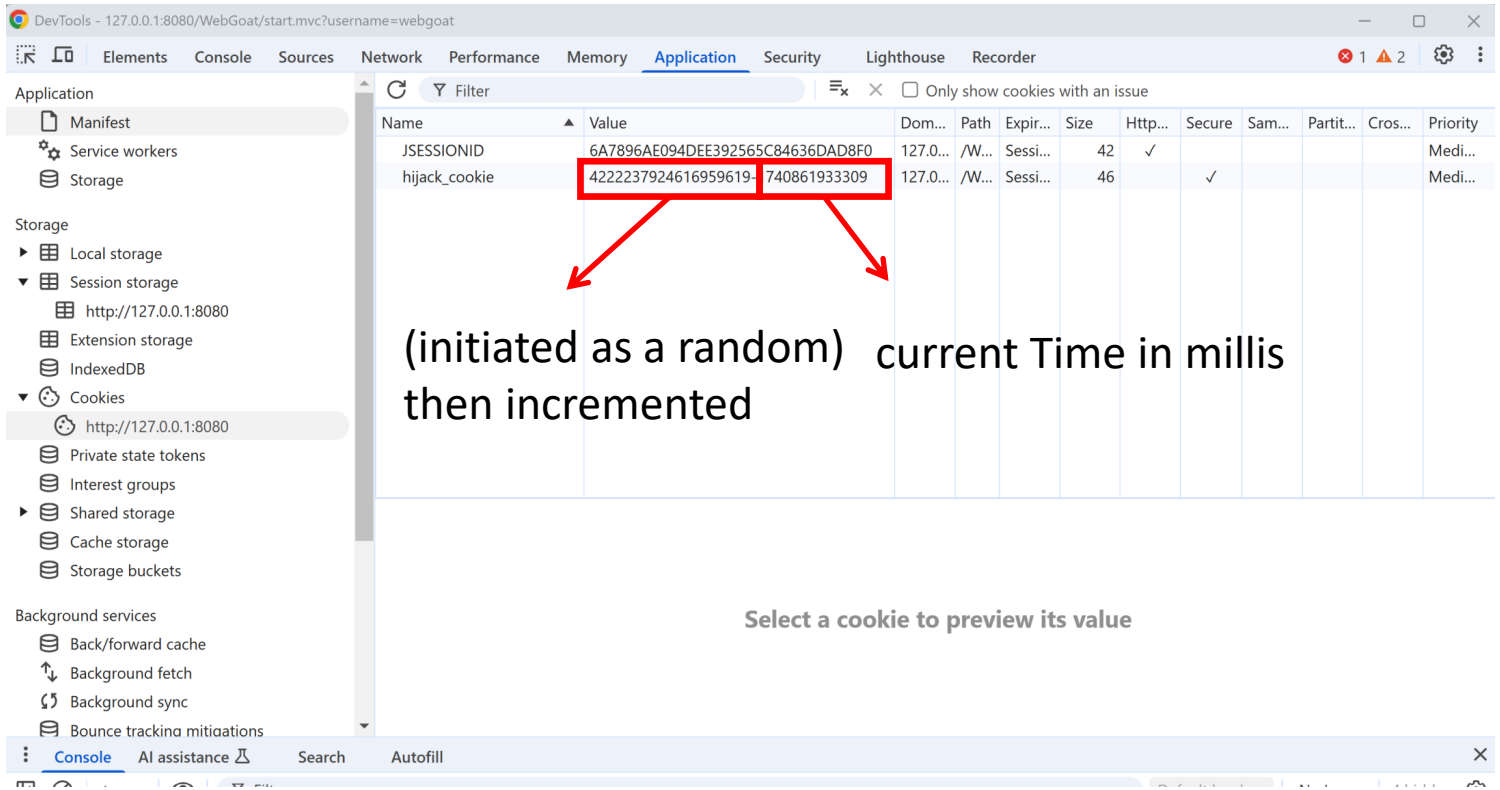
Show Hints


WEBGOAT
Hijack a session
Introduction
General
(A1) Broken Access Control
Hijack a session
Insecure Direct Object References
Missing Function Level Access Control
Show hints
Reset lesson
1
2


WEBGOAT
Hijack a session
Search lesson
Introduction
General
(A1) Broken Access Control
Hijack a session
Insecure Direct Object References
Missing Function Level Access Control
Spoofing an Authentication Cookie
(A2) Cryptographic Failures
(A3) Injection
(A5) Security Misconfiguration
Hide hints
Reset lesson
Check the 'hijack_cookie' cookie value and think about its format.
1
2
In this lesson we are trying to predict the 'hijack_cookie' value. The 'hijack_cookie' is used to differentiate authenticated and anonymous

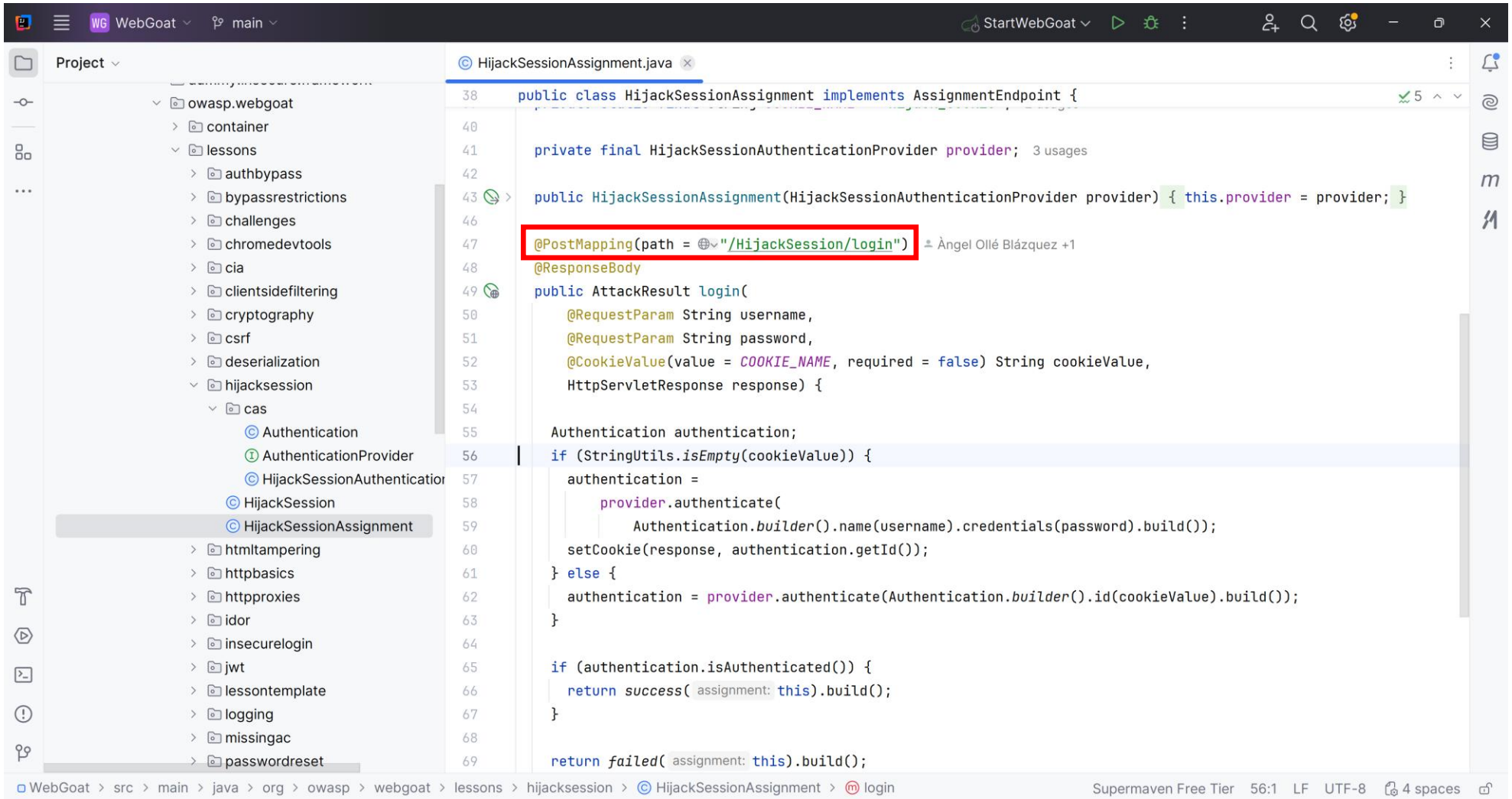

DevTools - 127.0.0.1:8080/WebGoat/start.mvc?username=webgoat
Elements
Console
Sources
Network
Performance
Memory
Application
Security
Lighthouse
Recorder
Application
Manifest
Service workers
Storage
Storage
Local storage
Session storage
http://127.0.0.1:8080
Extension storage
IndexedDB
Cookies
http://127.0.0.1:8080
Private state tokens
Interest groups
Shared storage
Cache storage
Storage buckets
Background services
Back/forward cache
Background fetch
Background sync
Bounce tracking mitigations
Filter
Only show cookies with an issue
Name
Value
Dom...
Path
Expir...
Size
Http...
Secure
Sam...
Partit...
Cros...
Priority
JSESSIONID
6A7896AE094DEE392565C84636DAD8F0
127.0...
/W...
Sessi...
42
✓
Medi...
hijack_cookie
4222237924616959619-1740861933309
127.0...
/W...
Sessi...
46
✓
Medi...
Select a cookie to preview its value
Console
AI assistance
Search
Autofill

Cookie is predictable ..



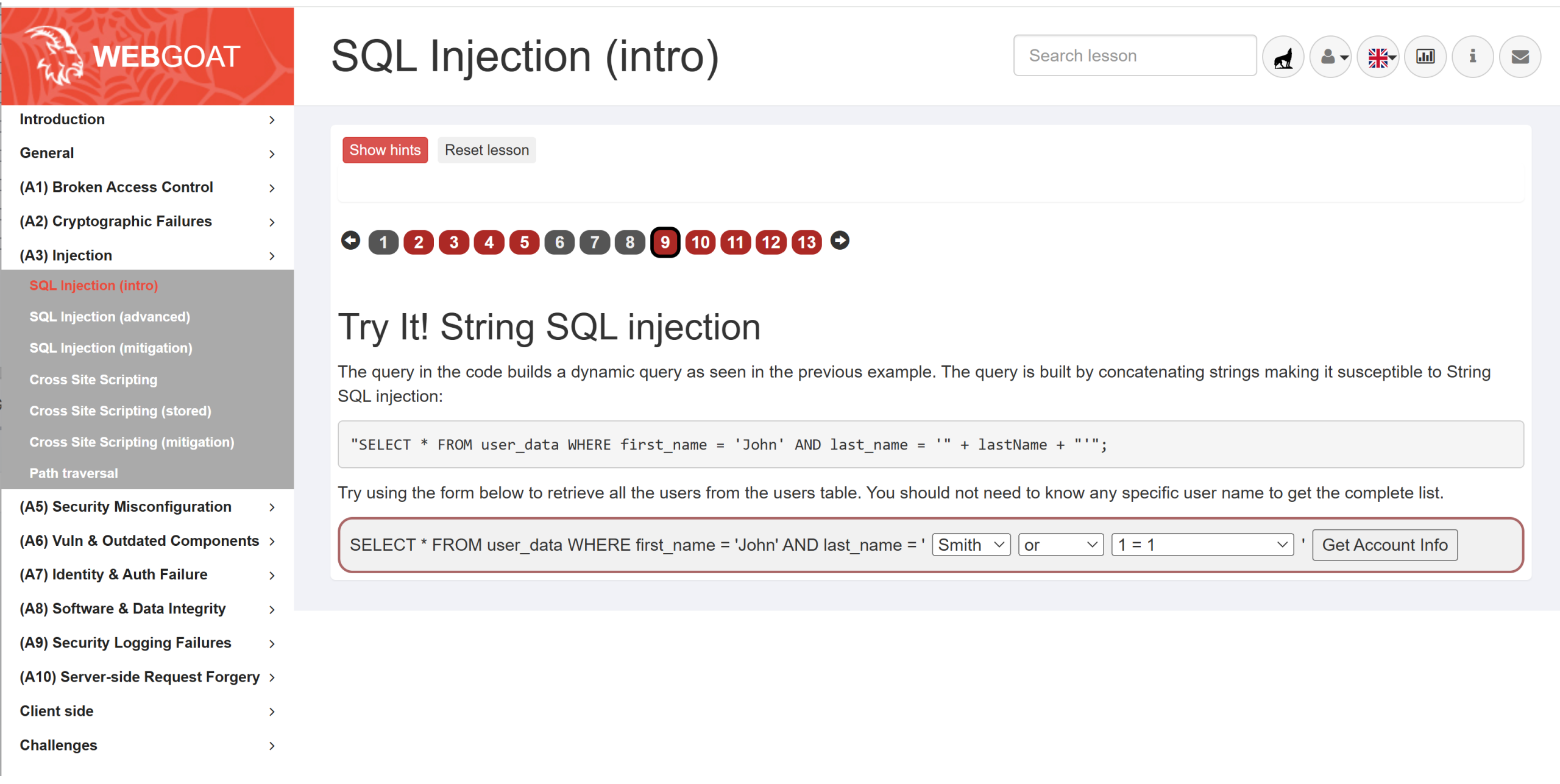
Search corresponding source Code ..

Here is http entry point: org\owasp\webgoat\lessons\hijacksession\HijackSessionAssignment.java
=> search corresponding bug in cookie generation / cookie usage

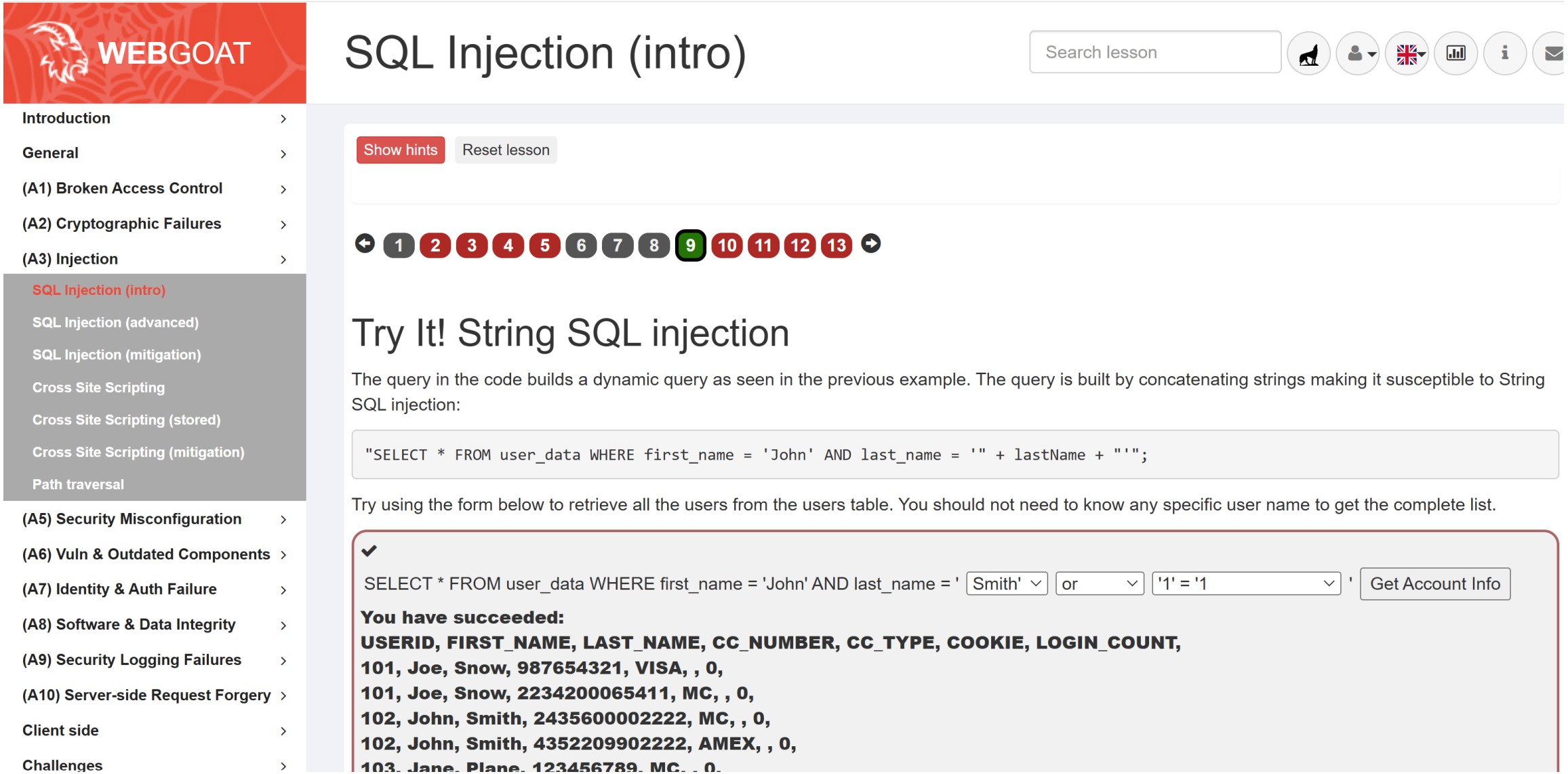


SQL Injection

SQL Injection



SQL Injection



Search "SQL Injection" Bug in Source Code

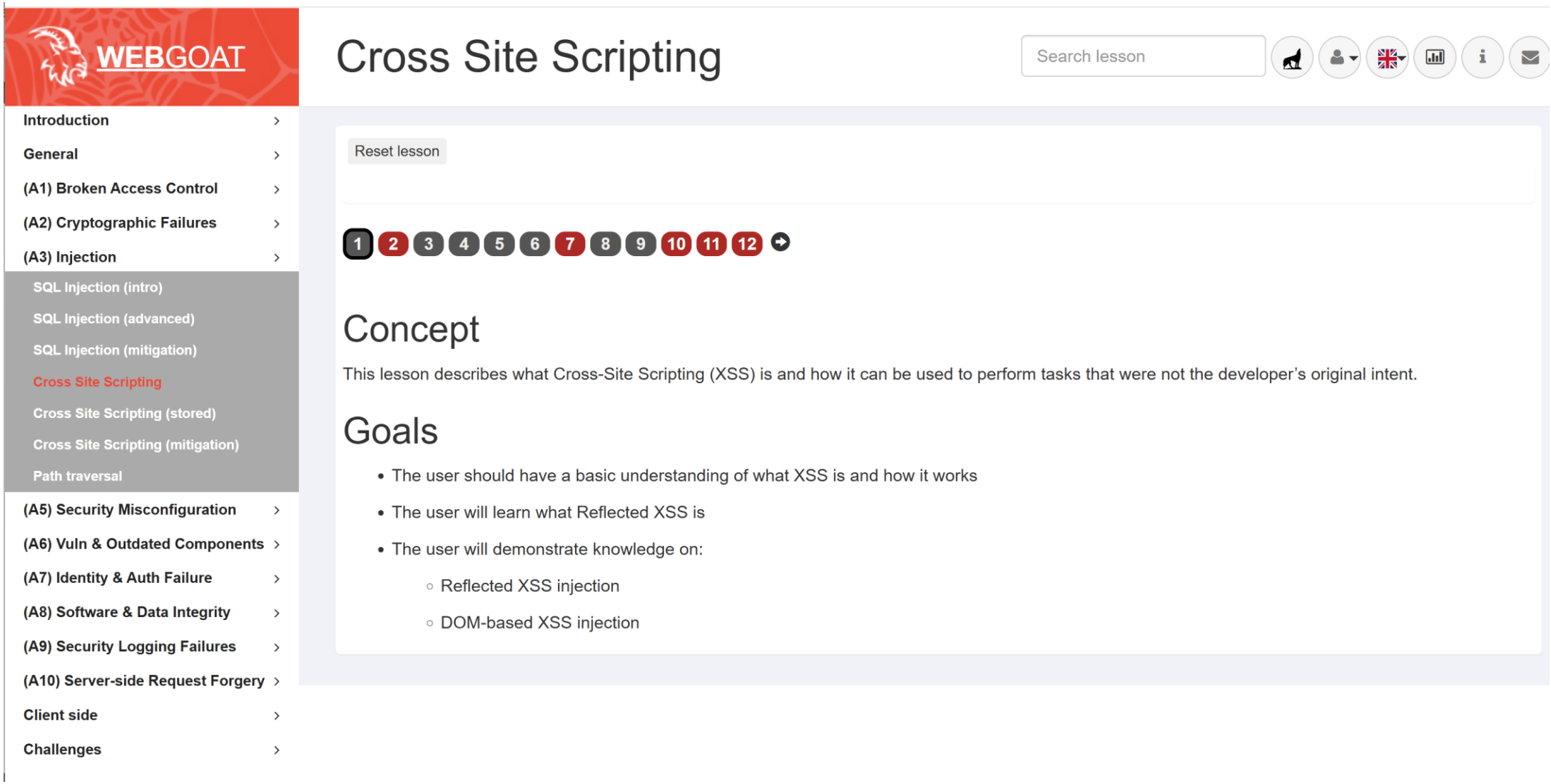
search code for example for SQL Injection "Lesson 9"

see package org.owasp.webgoat.lessons.sqlinjection.introduction
class SqlInjectionLesson9

Propose java jdbc correction to fix the bug

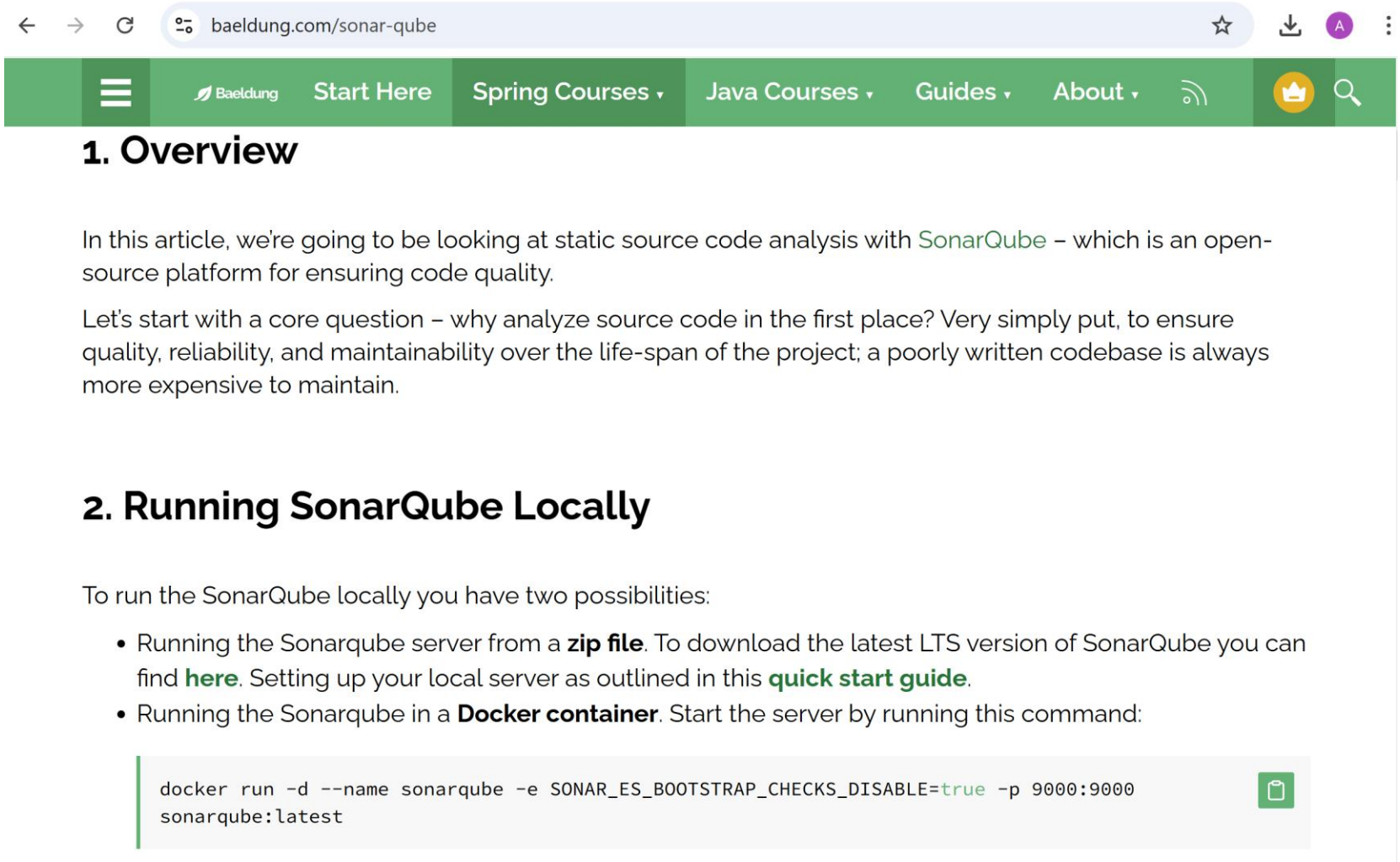
Cross Site Scripting

Cross Site Scripting

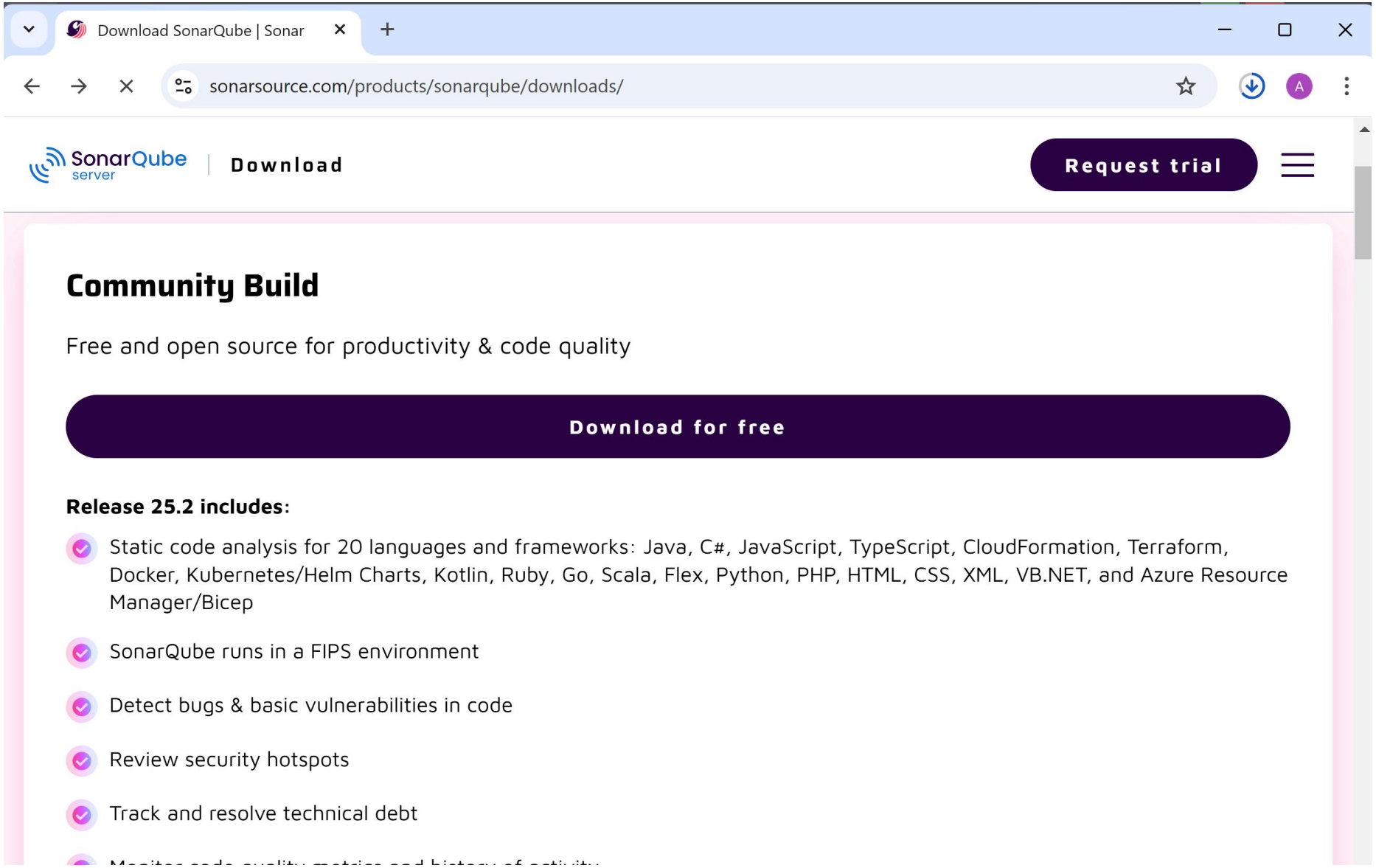


Using Java Source Code Analysis : Sonar

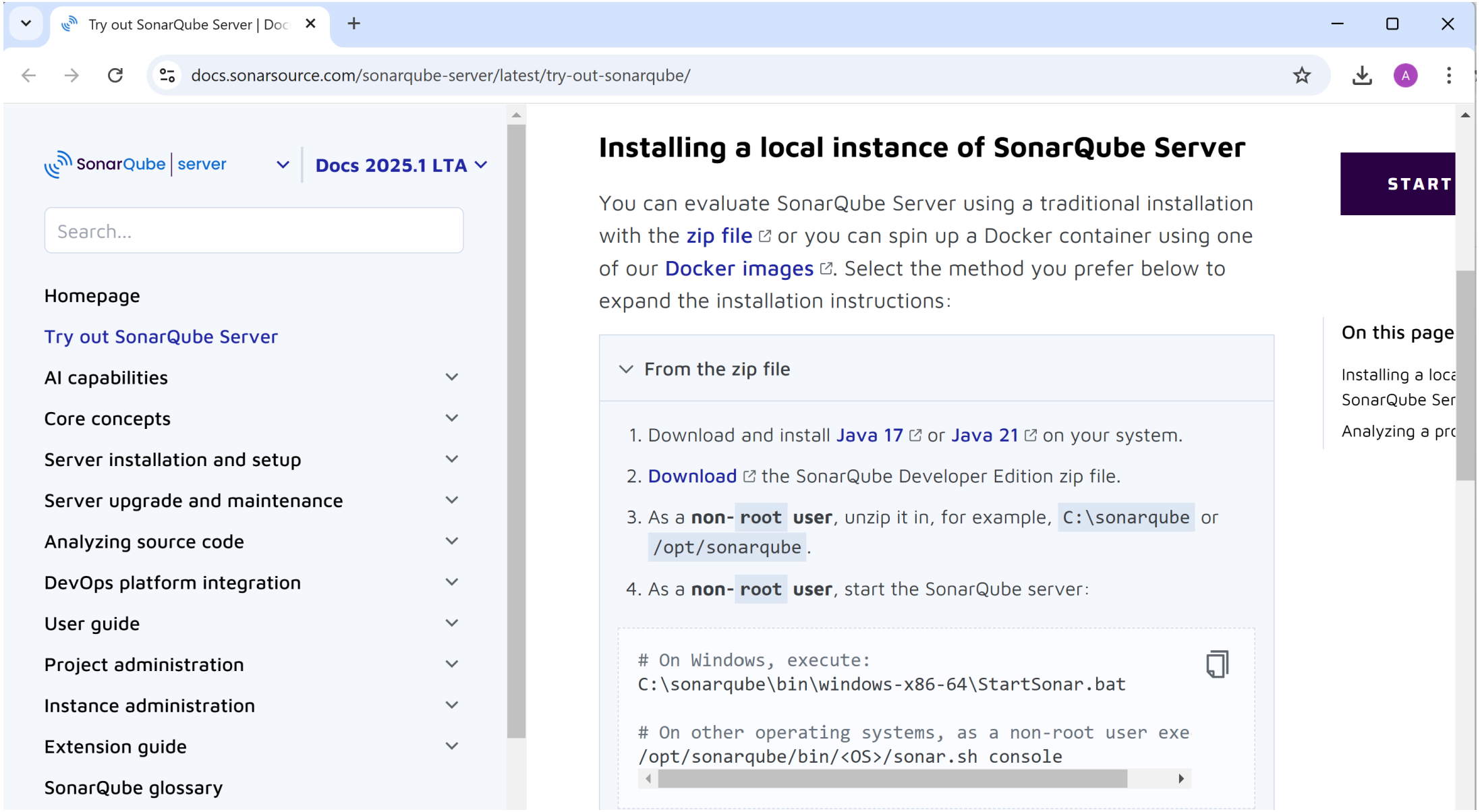
Example of Sonar Tutorial https://www.baeldung.com/sonar-qube



(no docker?) Download Sonar Server



(no docker?) Launch Sonar Server

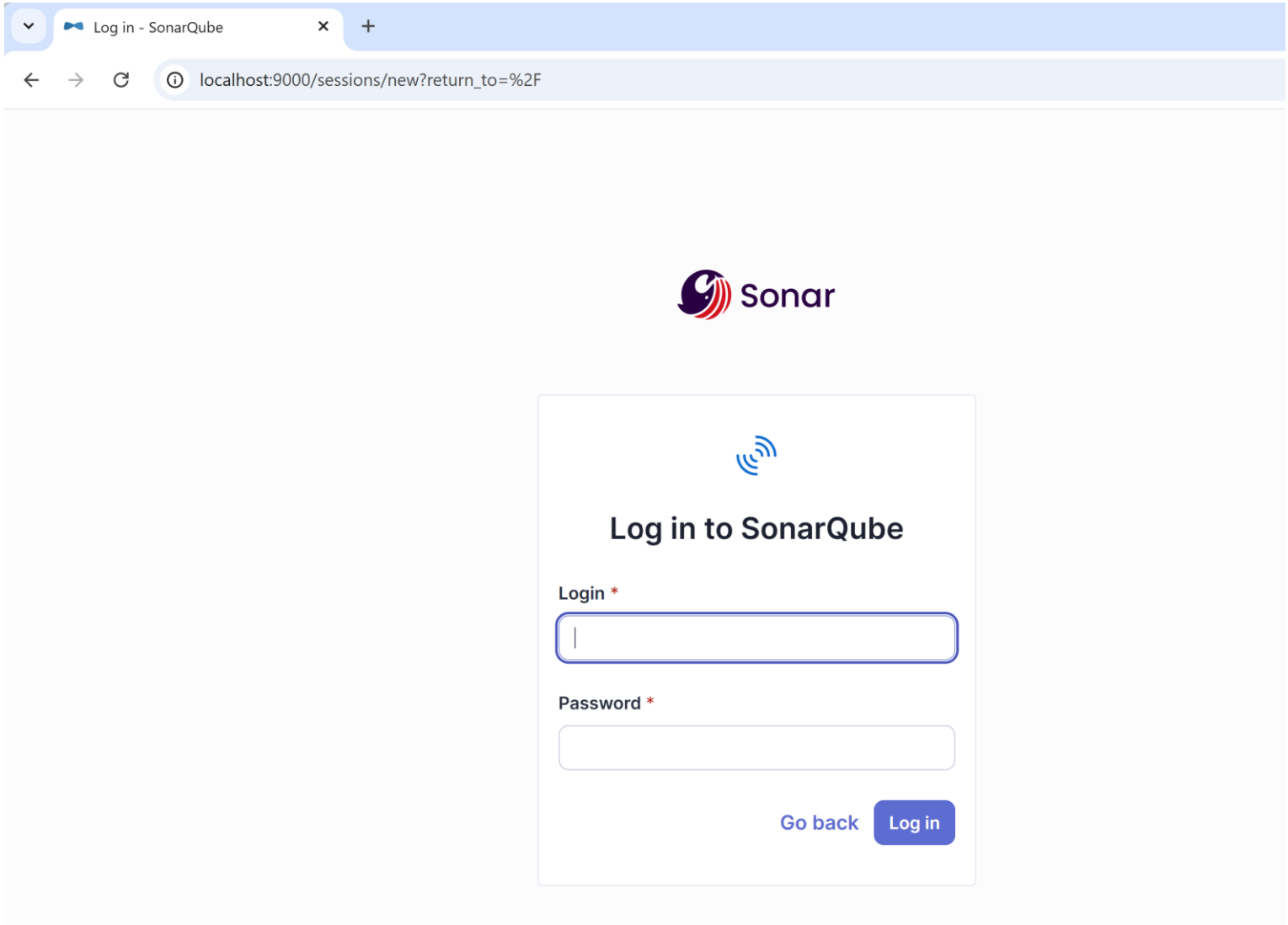


cd sonar
bin/windows-x86-64/StartSonar.bat

Cmder

```
arnaud@DesktopArnaud /cygdrive/c/apps/java/sonarqube-25.2.0.102705
$ bin/windows-x86-64/StartSonar.bat
Starting SonarQube...
2025.03.02 10:47:23 INFO  app[][o.s.a.AppFileSystem] Cleaning or creating temp directory C:\apps\java\sonarqube-25.2.0.102705\
temp
2025.03.02 10:47:23 INFO  app[][o.s.a.es.EsSettings] Elasticsearch listening on [HTTP: 127.0.0.1:9001, TCP: 127.0.0.1:{}]
2025.03.02 10:47:24 INFO  app[][o.s.a.ProcessLauncherImpl] Launch process[ELASTICSEARCH] from [C:\apps\java\sonarqube-25.2.0.1
02705\elasticsearch]: C:\apps\jdk\jdk-21\bin\java -Xms4m -Xmx64m -XX:+UseSerialGC -Dcli.name=server -Dcli.script=./bin/elastic
search -Dcli.libs=lib/tools/server-cli -Des.path.home=C:\apps\java\sonarqube-25.2.0.102705\elasticsearch -Des.path.conf=C:\app
s\java\sonarqube-25.2.0.102705\temp\conf\es -Des.distribution.type=tar -cp C:\apps\java\sonarqube-25.2.0.102705\elasticsearch\
lib\*;C:\apps\java\sonarqube-25.2.0.102705\elasticsearch\lib\cli-launcher\* org.elasticsearch.launcher.CliToolLauncher
2025.03.02 10:47:24 INFO  app[][o.s.a.SchedulerImpl] Waiting for Elasticsearch to be up and running
Standard Commons Logging discovery in action with spring-jcl: please remove commons-logging.jar from classpath in order to avo
id potential conflicts
mars 02, 2025 10:47:27 AM sun.util.locale.provider.LocaleProviderAdapter <clinit>
WARNING: COMPAT locale provider will be removed in a future release
2025.03.02 10:47:40 INFO  app[][o.s.a.SchedulerImpl] Process[es] is up
2025.03.02 10:47:40 INFO  app[][o.s.a.ProcessLauncherImpl] Launch process[WEB_SERVER] from [C:\apps\java\sonarqube-25.2.0.1027
05]: C:\apps\jdk\jdk-21\bin\java -Djava.awt.headless=true -Dfile.encoding=UTF-8 -Djava.io.tmpdir=C:\apps\java\sonarqube-25.2.0
.102705\temp -XX:-OmitStackTraceInFastThrow --add-opens=java.base/java.util=ALL-UNNAMED --add-opens=java.base/java.lang=ALL-UN
NAMED --add-opens=java.base/java.io=ALL-UNNAMED --add-opens=java.rmi/sun.rmi.transport=ALL-UNNAMED --add-exports=java.base/jdk
.internal.ref=ALL-UNNAMED --add-opens=java.base/java.nio=ALL-UNNAMED --add-opens=java.base/sun.nio.ch=ALL-UNNAMED --add-opens=
java.management/sun.management=ALL-UNNAMED --add-opens=jdk.management/com.sun.management.internal=ALL-UNNAMED -Xmx512m -Xms128
m -XX:+HeapDumpOnOutOfMemoryError -Dhttp.nonProxyHosts=localhost|127.*|[::1] -cp ./lib/sonar-application-25.2.0.102705.jar;C:\
apps\java\sonarqube-25.2.0.102705\lib\jdbc\h2\h2-2.3.232.jar org.sonar.server.app.WebServer C:\apps\java\sonarqube-25.2.0.1027
```

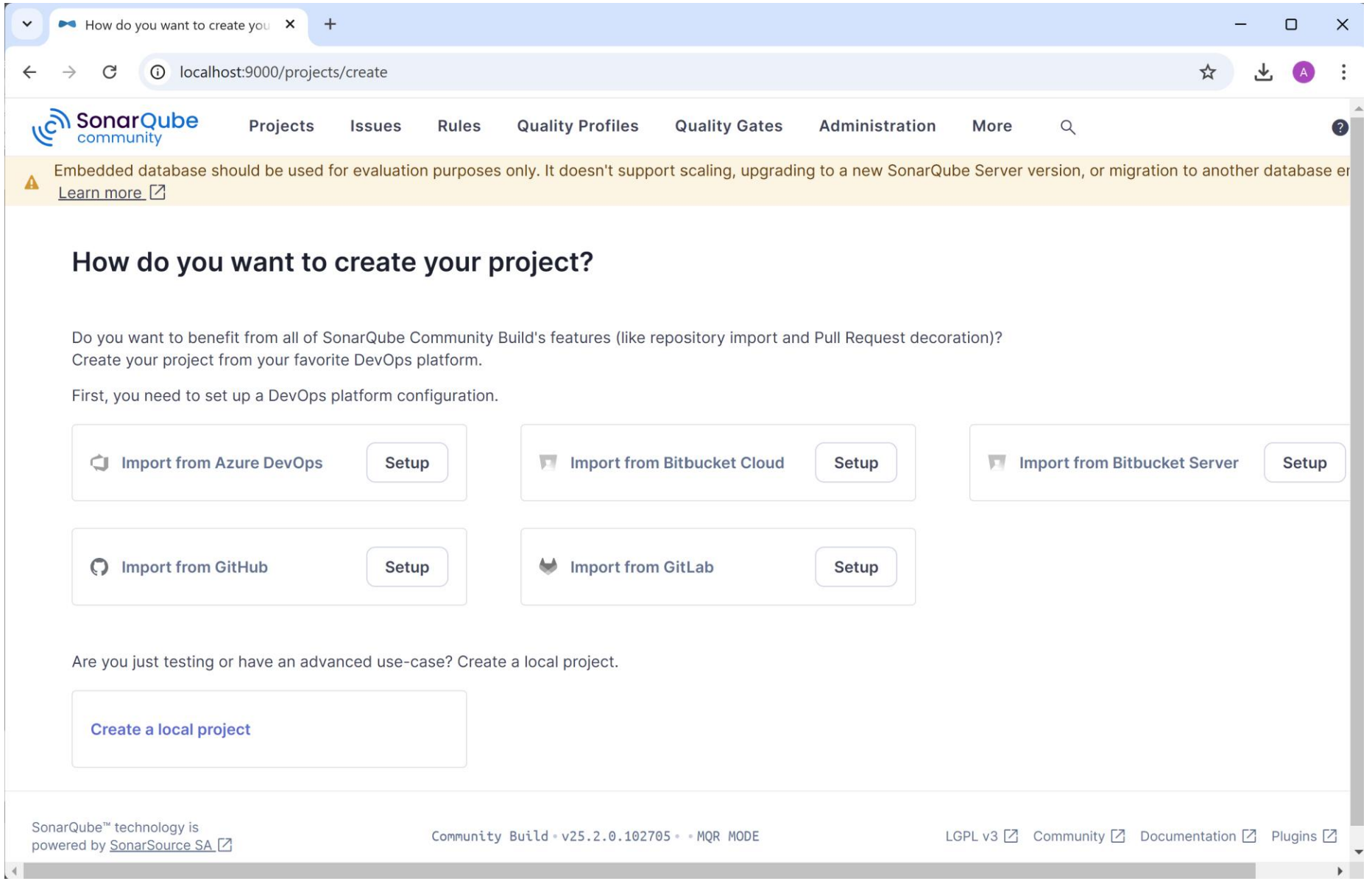
open sonar Web http://localhost:9000



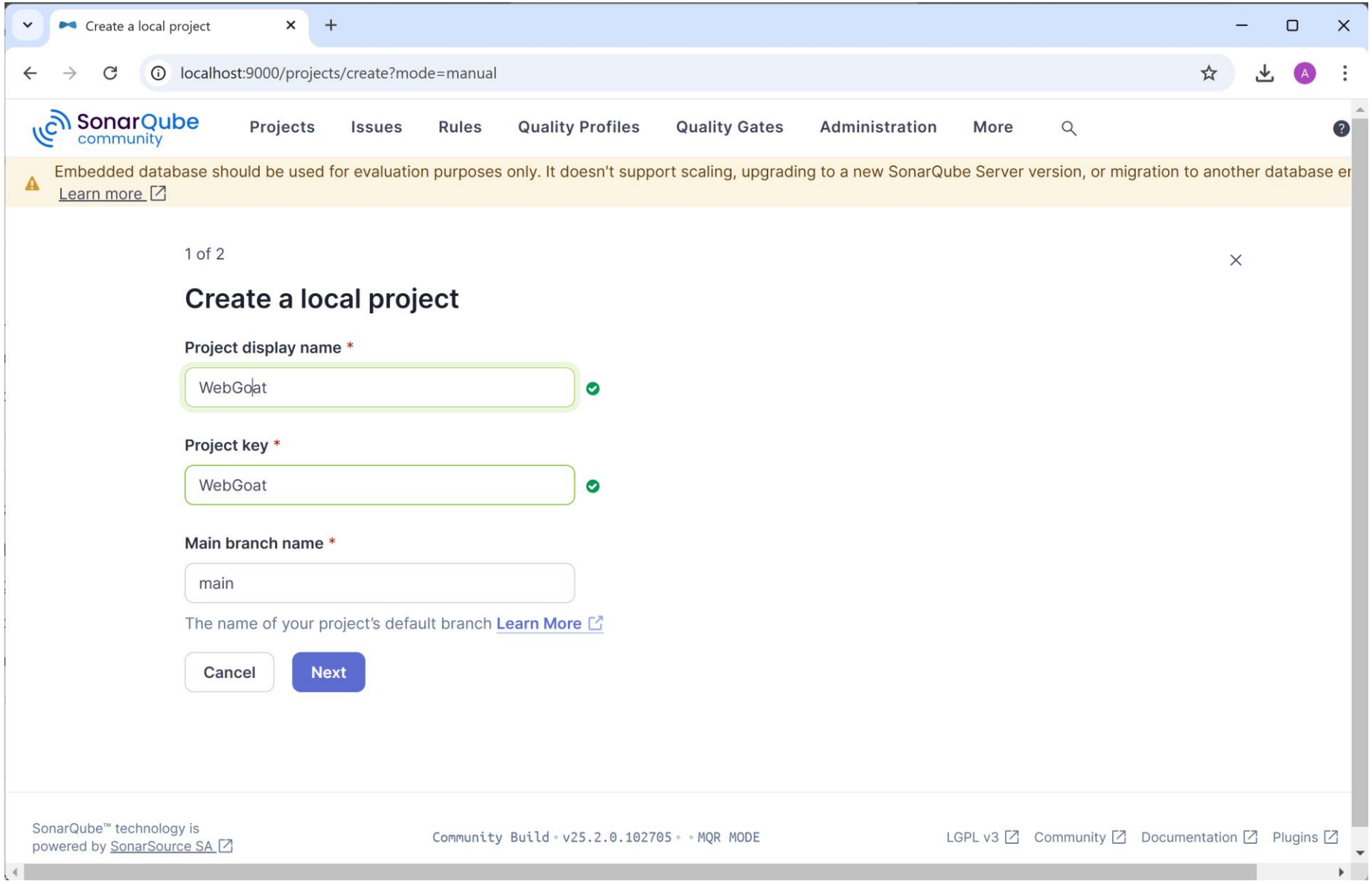
use login/password
"admin" / "admin"

then prompted to change

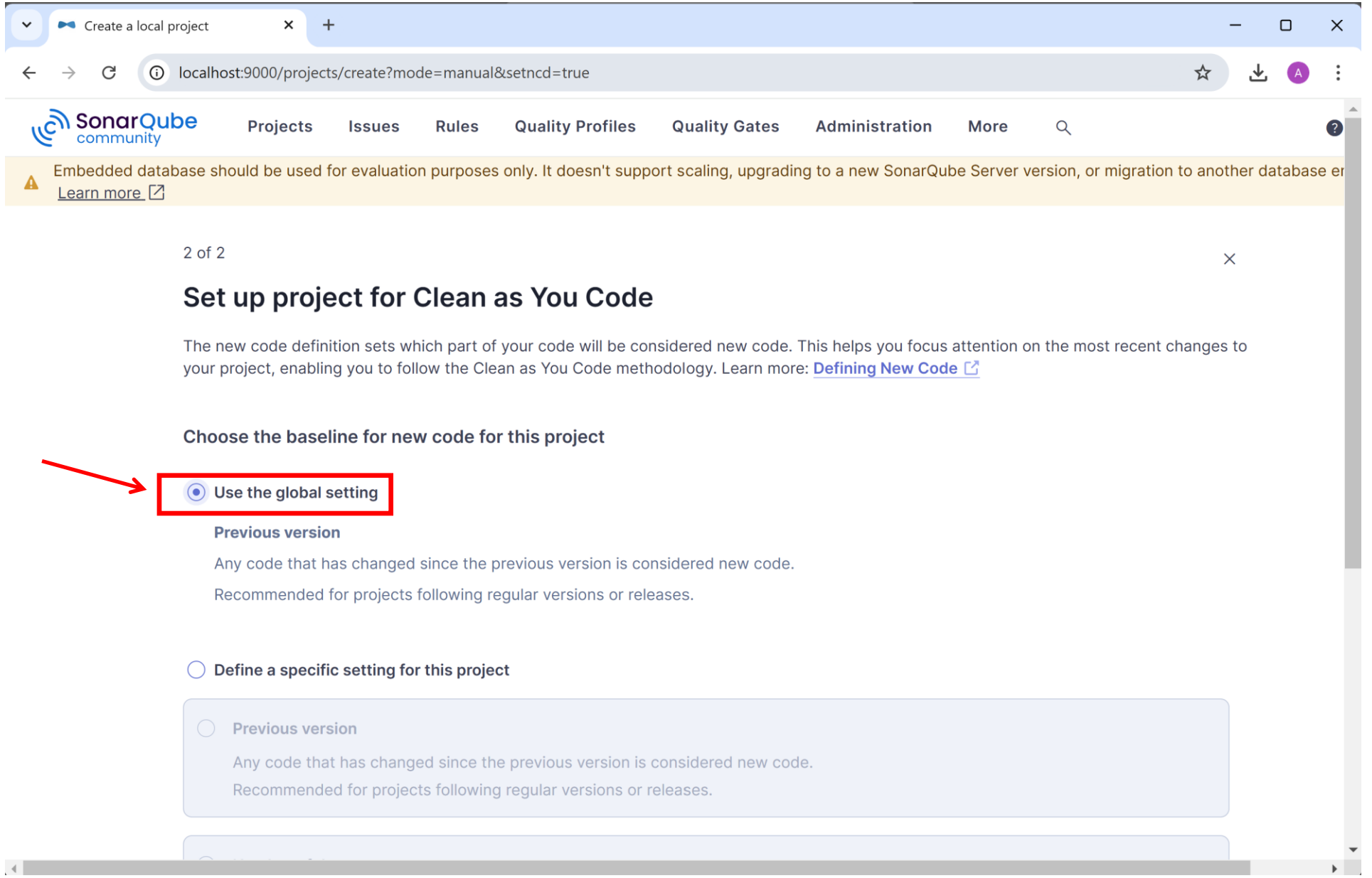
Sonar Web Home Page



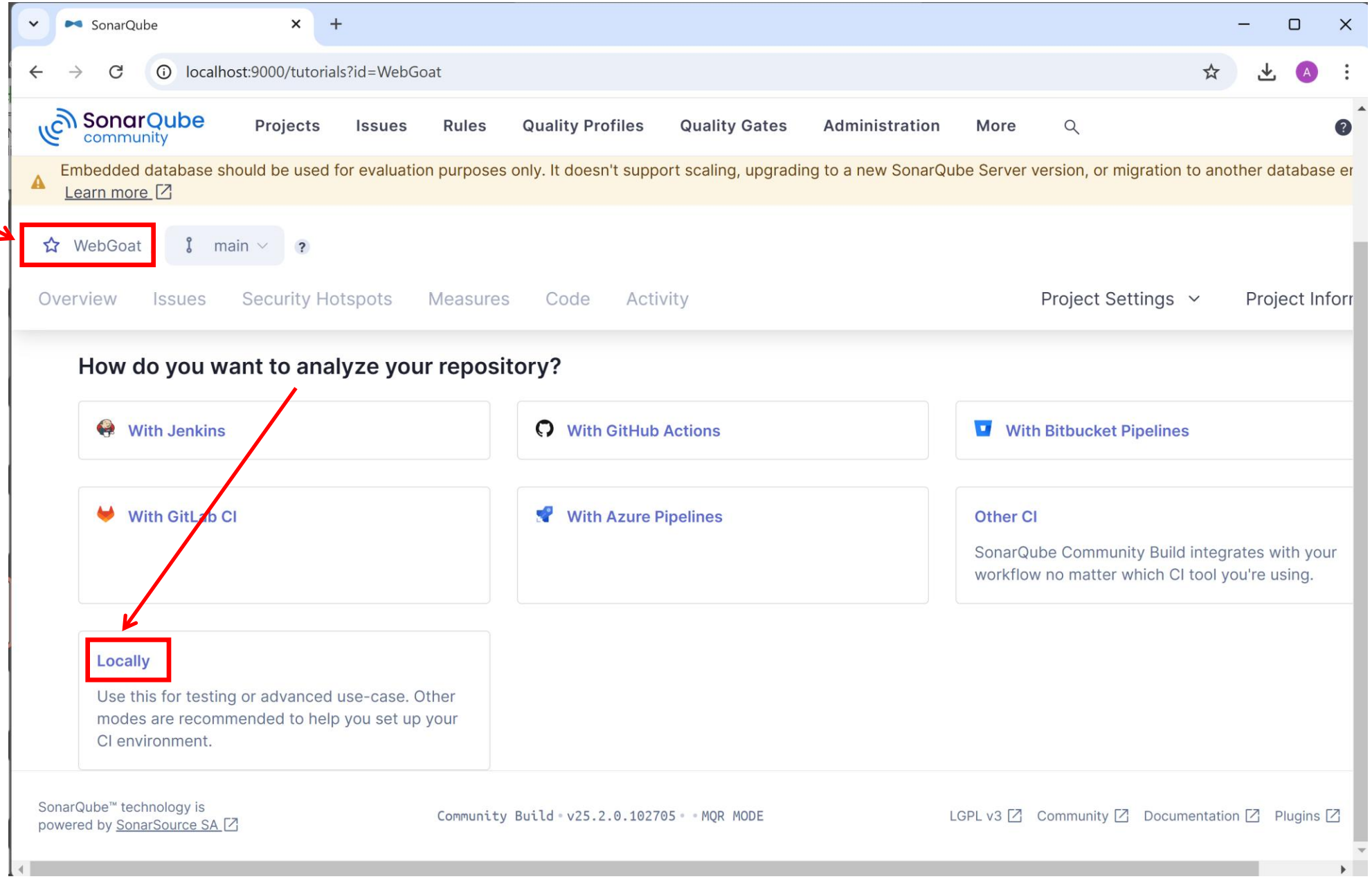
Create a Local Project



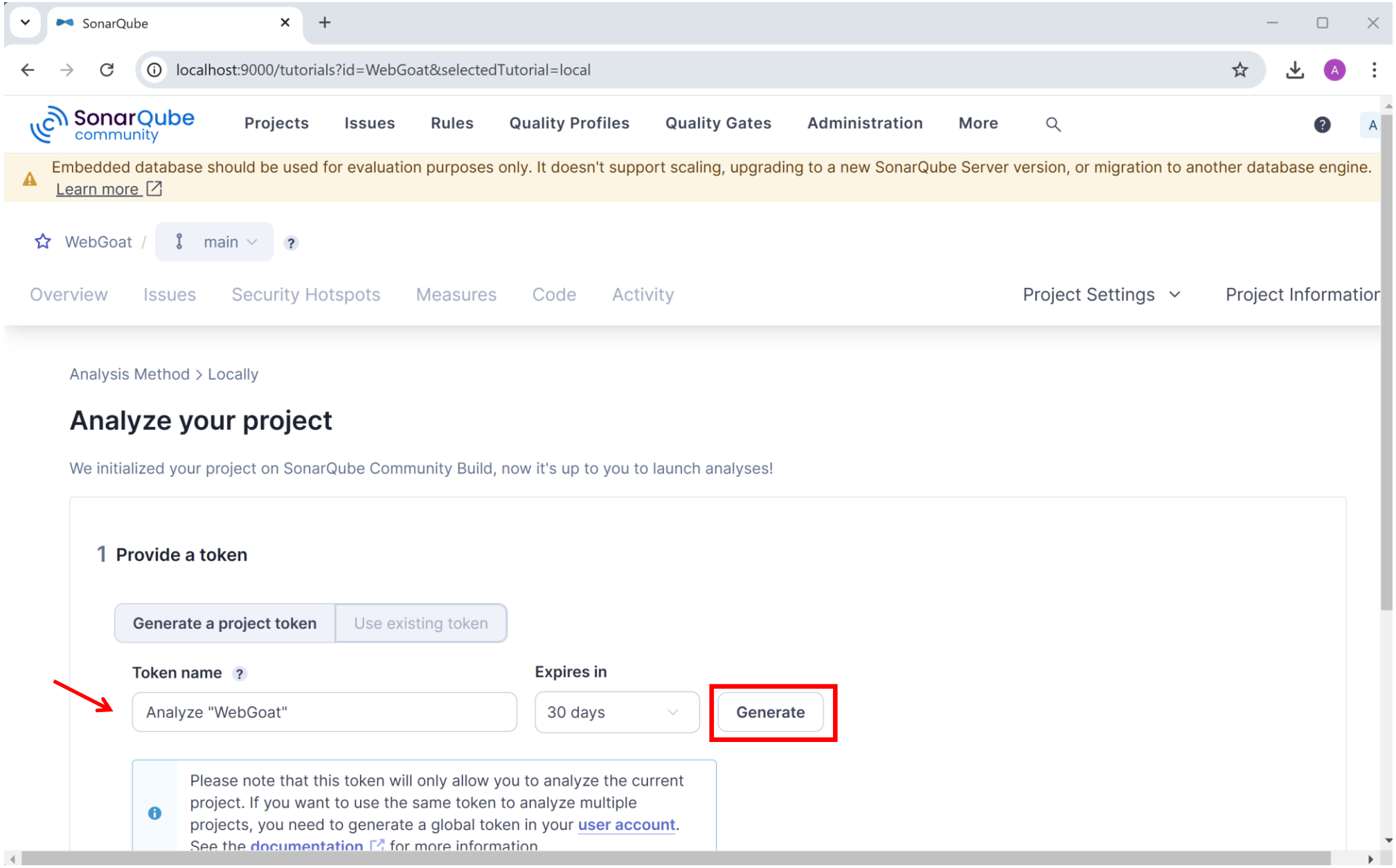
select "Use the global settings"



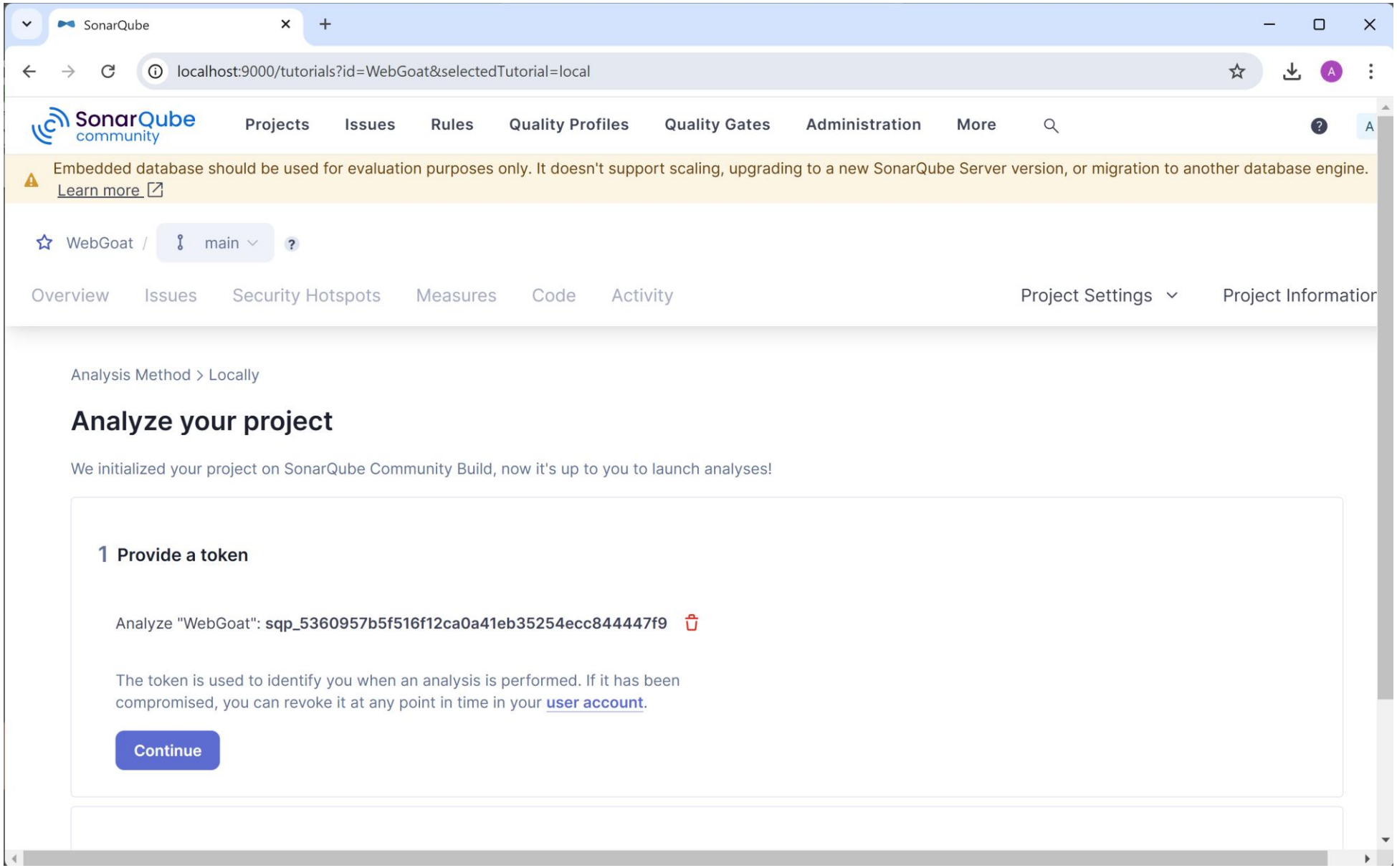
Project Created .. click on Analyse "Locally"



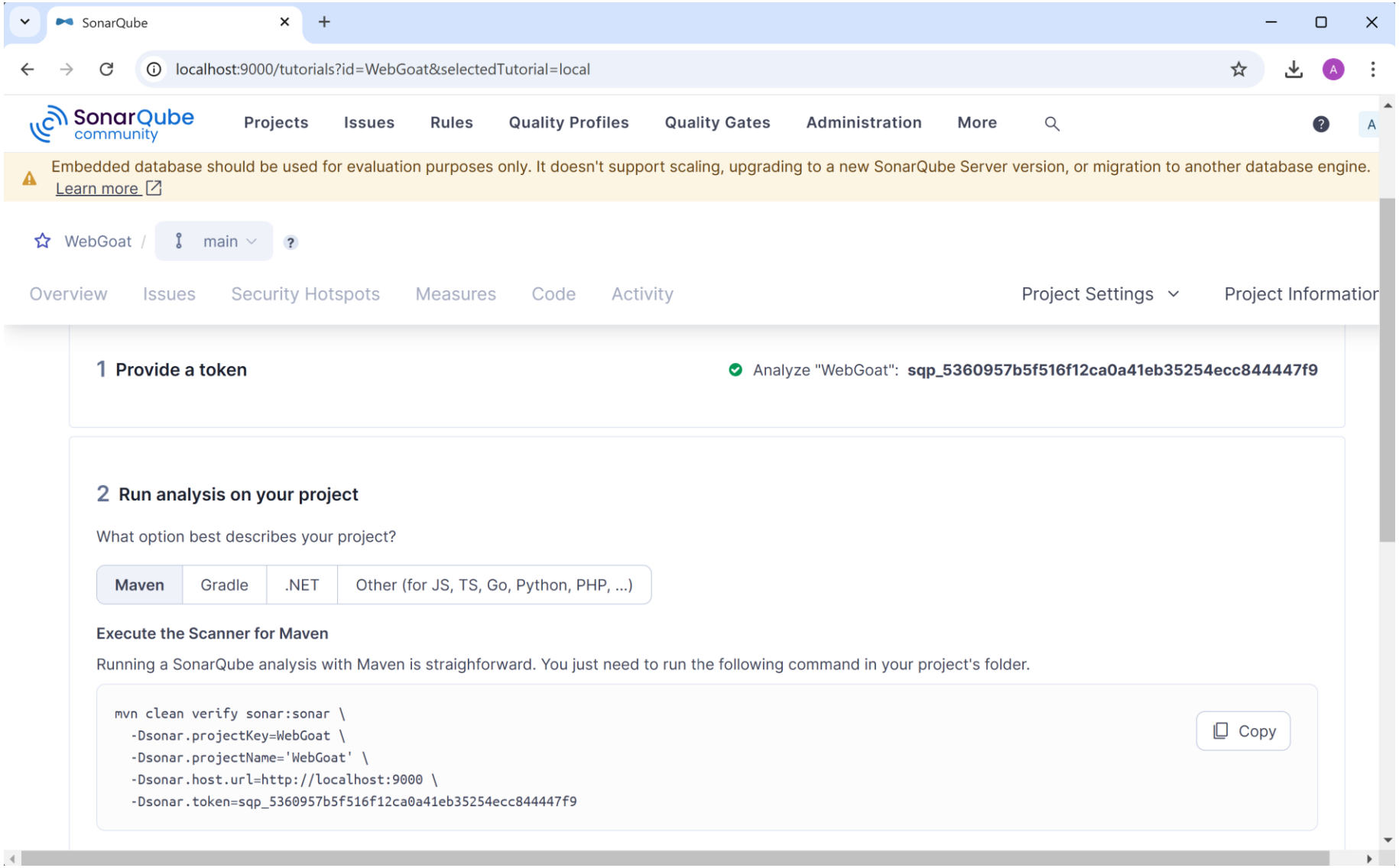
Generate a Token



Token to copy



describe "Maven" => copy command "mvn verify sonar:sonar -Dsonar..."



mvn verify sonar:sonar ...

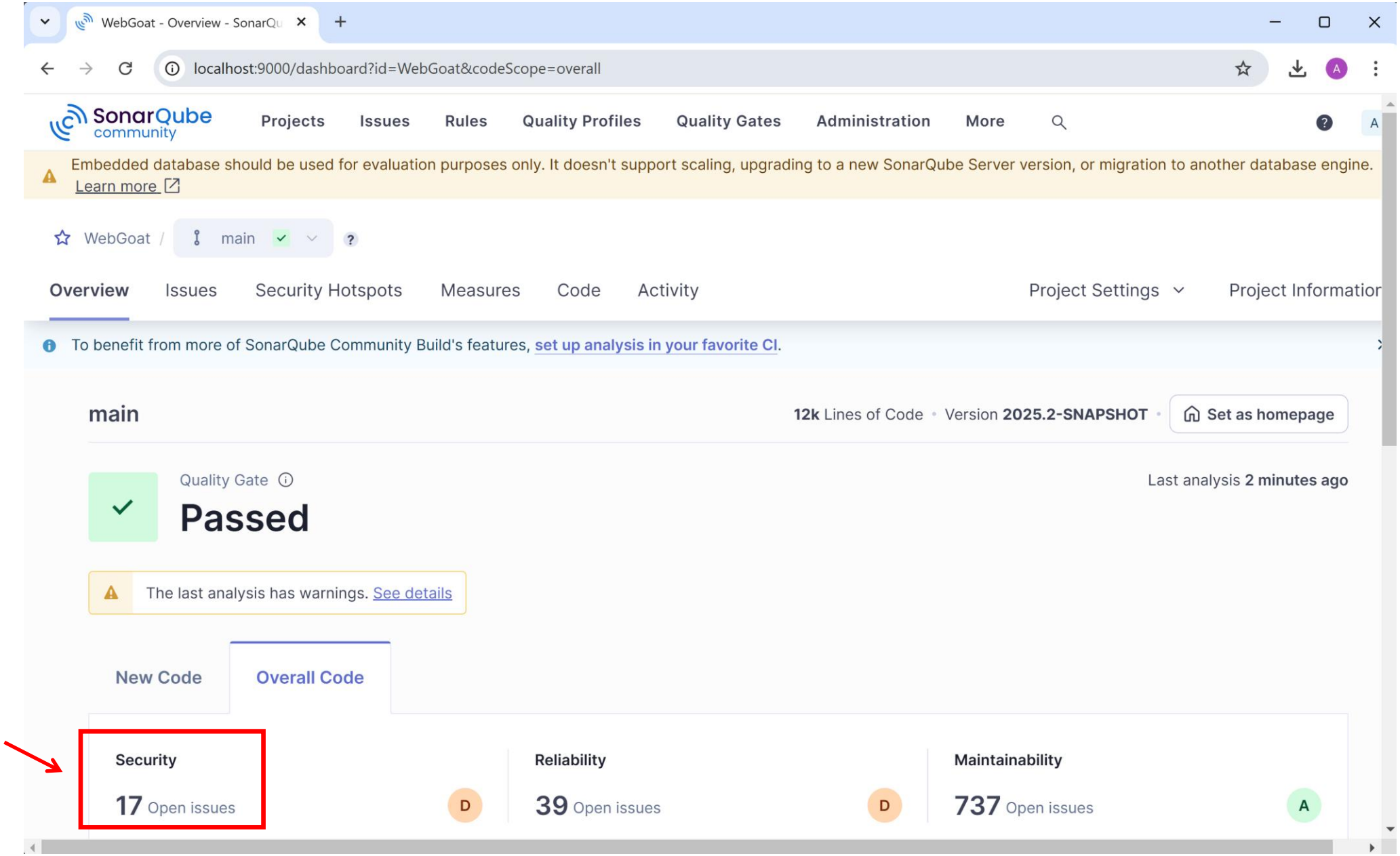
```
$ mvn verify sonar:sonar   -Dsonar.projectKey=WebGoat   -Dsonar.projectName='WebGoat'   -Dsonar.host.url=http://localhost:9
f516f12ca0a41eb35254ecc844447f9
[INFO] Scanning for projects...
[WARNING] The artifact org.codehaus.mojo:sonar-maven-plugin:jar:4.0.0.4121 has been relocated to org.sonarsource.scanner.ma
121: SonarQube plugin was moved to SonarSource organisation
[INFO]
[INFO] ----------------------< org.owasp.webgoat:webgoat >----------------------
[INFO] Building WebGoat 2025.2-SNAPSHOT
[INFO]   from pom.xml
[INFO] --------------------------------[ jar ]---------------------------------
[INFO]
[INFO] --- enforcer:3.5.0:enforce (restrict-log4j-versions) @ webgoat ---
[INFO] Rule 0: org.apache.maven.enforcer.rules.dependency.BannedDependencies passed
[INFO]
[INFO] --- resources:3.3.1:resources (default-resources) @ webgoat ---
[INFO] Copying 2 resources from src\main\resources to target\classes
```

mvn sonar:sonar

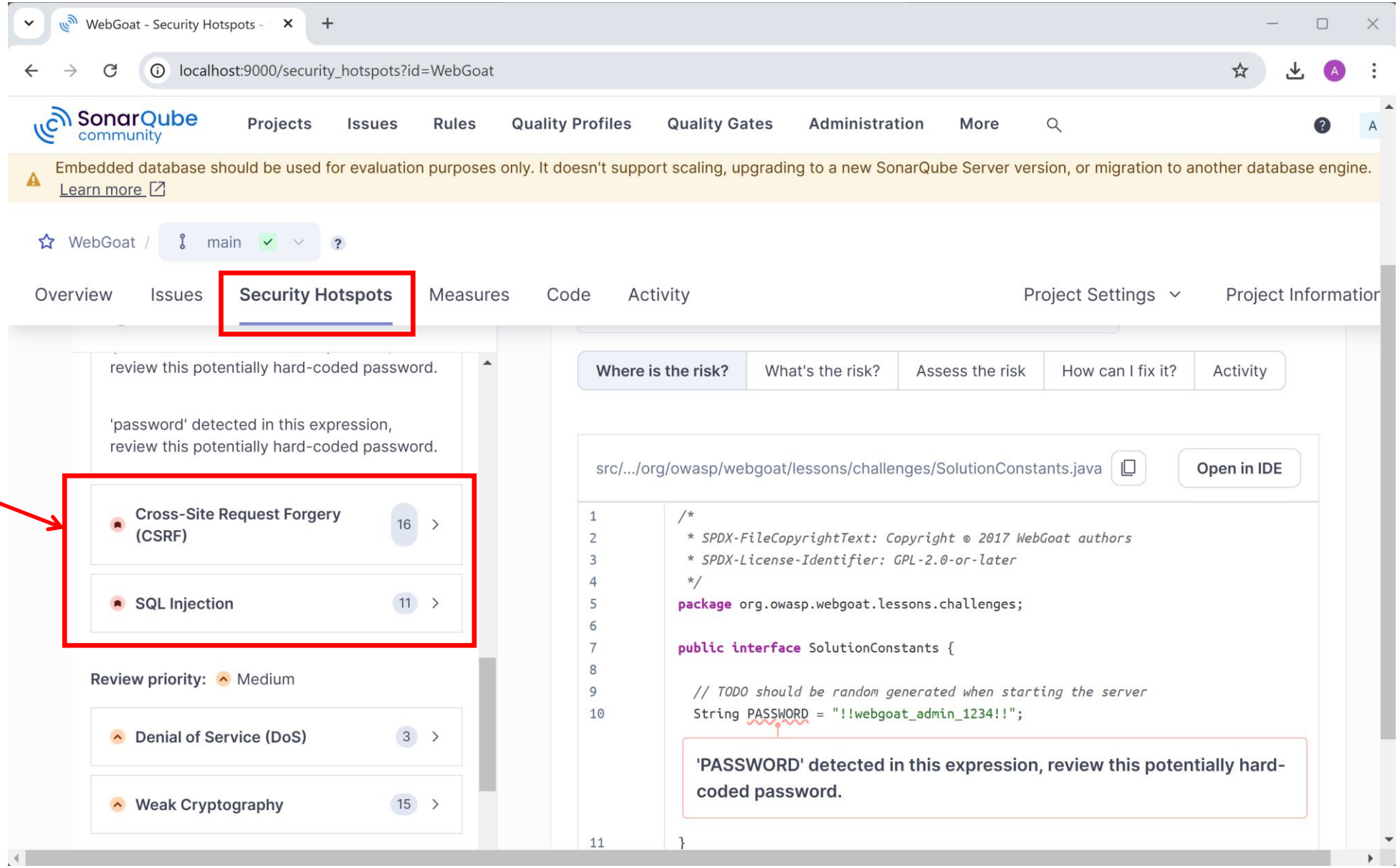
Cmder

```
[INFO] 11:21:34.584 Sensor Java CPD Block Indexer (done) | time=273ms
[INFO] 11:21:34.590 SCM Publisher SCM provider for this project is: git
[INFO] 11:21:34.591 SCM Publisher 370 source files to be analyzed
[INFO] 11:21:38.019 SCM Publisher 369/370 source files have been analyzed (done) | time=3427ms
[WARNING] 11:21:38.020 Missing blame information for the following files:
[WARNING] 11:21:38.020   * pom.xml
[WARNING] 11:21:38.021 This may lead to missing/broken features in SonarQube
[INFO] 11:21:38.050 CPD Executor 89 files had no CPD blocks
[INFO] 11:21:38.051 CPD Executor Calculating CPD for 171 files
[INFO] 11:21:38.297 CPD Executor CPD calculation finished (done) | time=246ms
[INFO] 11:21:38.317 SCM revision ID 'c37a8e8c19ac4fd127d1e11d6edc03ffcb2eefa1'
[INFO] 11:21:39.354 Analysis report generated in 852ms, dir size=2.0 MB
[INFO] 11:21:43.550 Analysis report compressed in 4196ms, zip size=1.1 MB
[INFO] 11:21:43.706 Analysis report uploaded in 155ms
[INFO] 11:21:43.711 ANALYSIS SUCCESSFUL, you can find the results at: http://localhost:9000/dashboard?id=WebGoat
[INFO] 11:21:43.711 Note that you will be able to access the updated dashboard once the server has processed the submitted analysis report
[INFO] 11:21:43.712 More about the report processing at http://localhost:9000/api/ce/task?id=14858bdb-986c-4c93-be6d-3e1b7d6aee08
[INFO] 11:21:44.781 Analysis total time: 47.687 s
[INFO] ------------------------------------------------------------------------
[INFO] BUILD SUCCESS
[INFO] ------------------------------------------------------------------------
[INFO] Total time:  01:45 min
[INFO] Finished at: 2025-03-02T11:21:44+01:00
[INFO] ------------------------------------------------------------------------
```

Refresh Sonar Page … 17 security issues detected

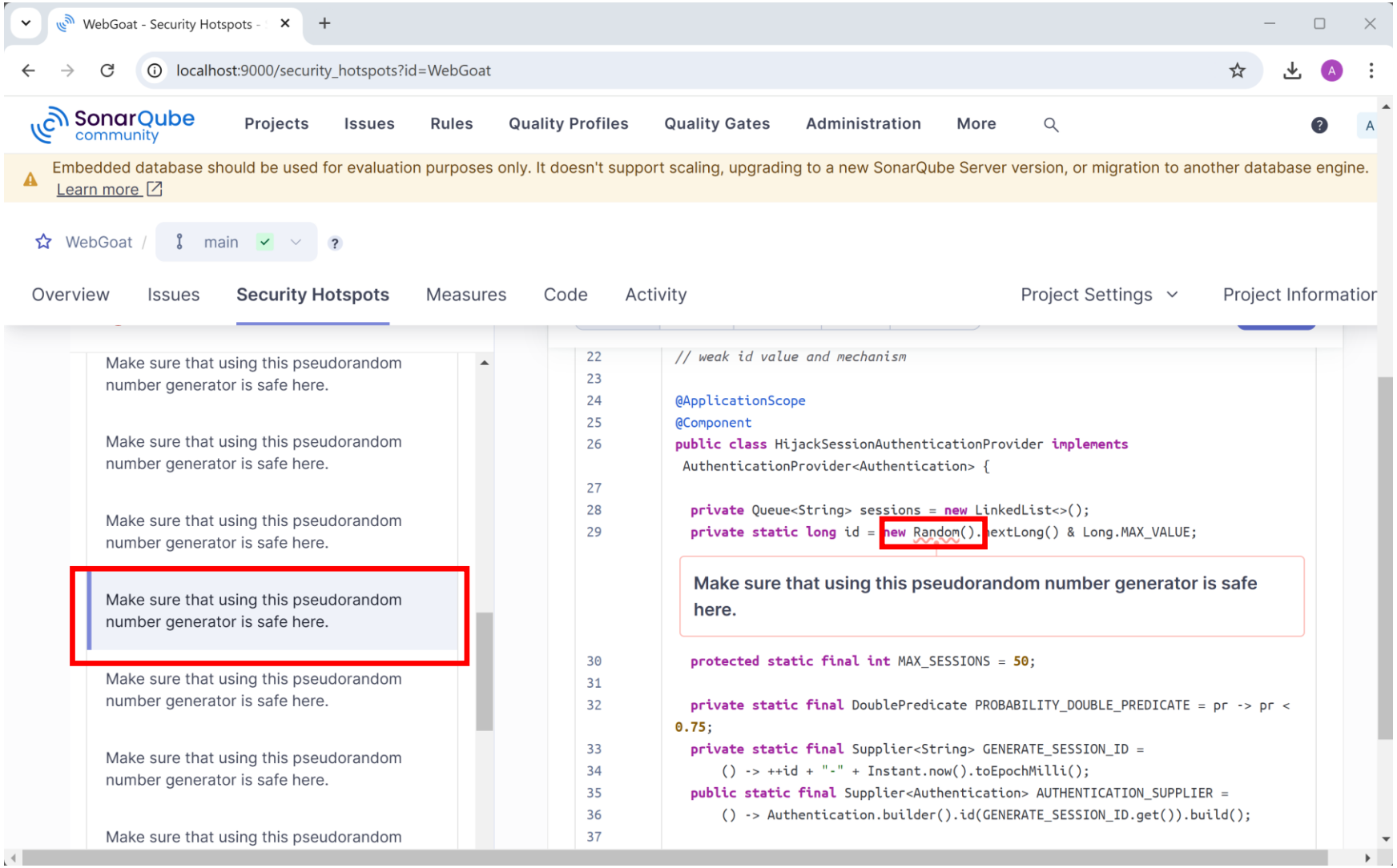


also Security Hotspot detected

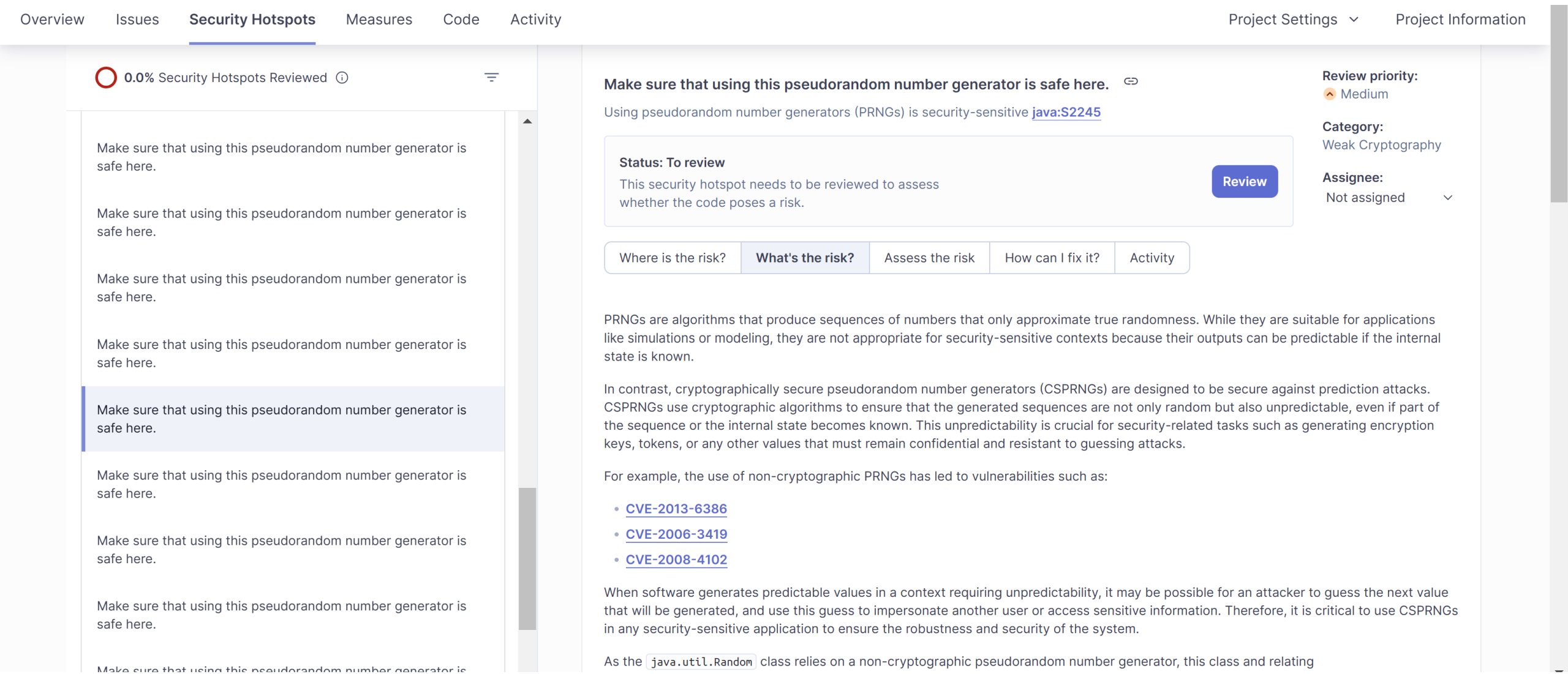


Back on exercise 1 ... "Hijack Session Cookie" analysis with Sonar

Notice ... Security bug "partly" spoted by Sonar (see next for sonar)



sonar "What is the risk?"



Sonar "Why is this an issue ?"

Overview | **Issues** | Security Hotspots | Measures | Code | Activity | Project Settings | Project Information

1 issues

src/.../cas/HijackSessionAuthenticatio...

Save and re-use this "Random".

Save and re-use this "Random".

"Random" objects should be reused java:S2119

Line affected: **L29** • Effort: **5min** • Introduced: **2 years ago**

Open | Not assigned | No tags +

Where is the issue? | **Why is this an issue?** | How can I fix it? | Activity | More info

Software qualities impacted

Reliability

Clean code attribute

Intentionality | Not complete

Creating a new `Random` object each time a random value is needed is inefficient and may produce numbers that are not random, depending on the JDK. For better efficiency and randomness, create a single `Random`, store it, and reuse it.

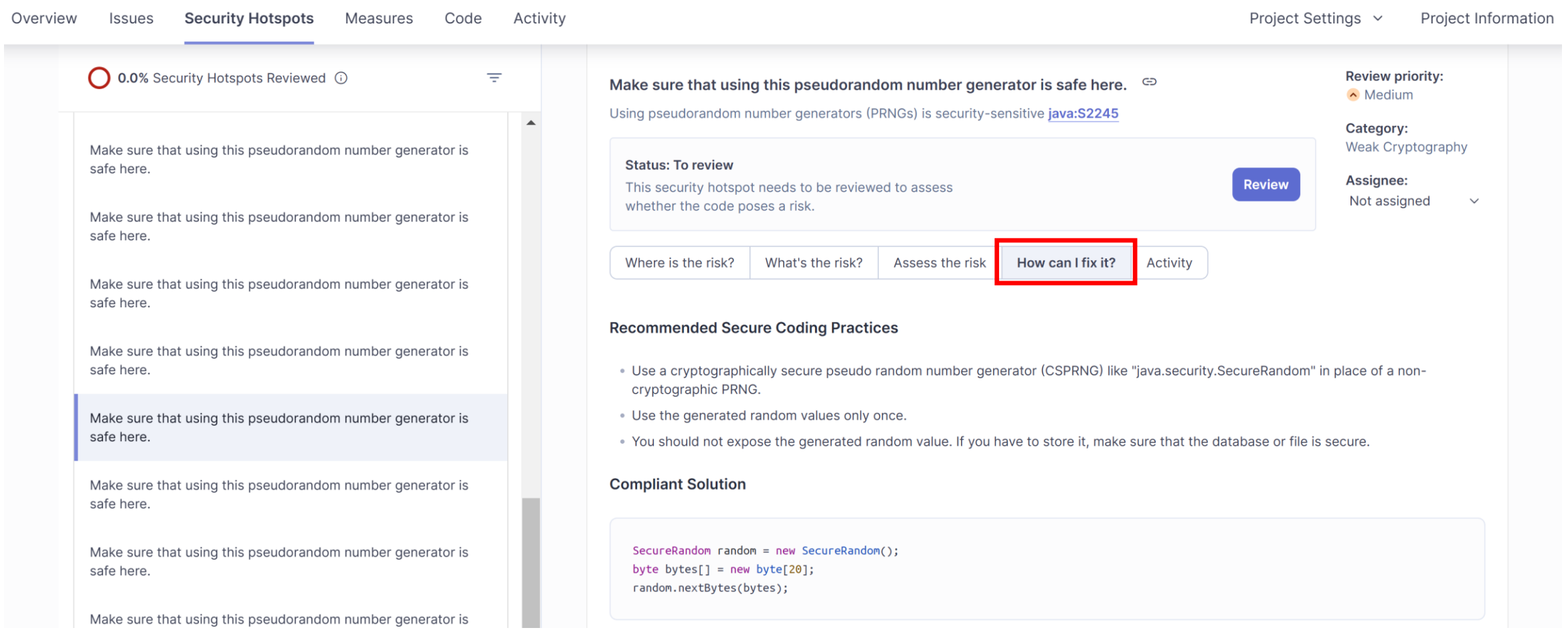
The `Random()` constructor tries to set the seed with a distinct value every time. However, there is no guarantee that the seed will be randomly or uniformly distributed. Some JDK will use the current time as seed, making the generated numbers not random.

This rule finds cases where a new `Random` is created each time a method is invoked.

Exceptions

This rule doesn't apply to classes that use a `Random` in their constructors or the static `main` function and nowhere else.

Sonar "How can I fix it ?"



"Random" instead of "SecureRandom" is a bug
BUT Also repeating "new Random()" is another bug

Overview | **Issues** | Security Hotspots | Measures | Code | Activity | Project Settings | Project Information

1 issues

src/.../cas/HijackSessionAuthenticatio...

Save and re-use this "Random".

Save and re-use this "Random".

"Random" objects should be reused java:S2119

Line affected: **L29** • Effort: **5min** • Introduced: **2 years ago**

Open | Not assigned | No tags +

Where is the issue? | **Why is this an issue?** | How can I fix it? | Activity | More info

Software qualities impacted

Reliability

Clean code attribute

Intentionality | Not complete

Creating a new `Random` object each time a random value is needed is inefficient and may produce numbers that are not random, depending on the JDK. For better efficiency and randomness, create a single `Random`, store it, and reuse it.

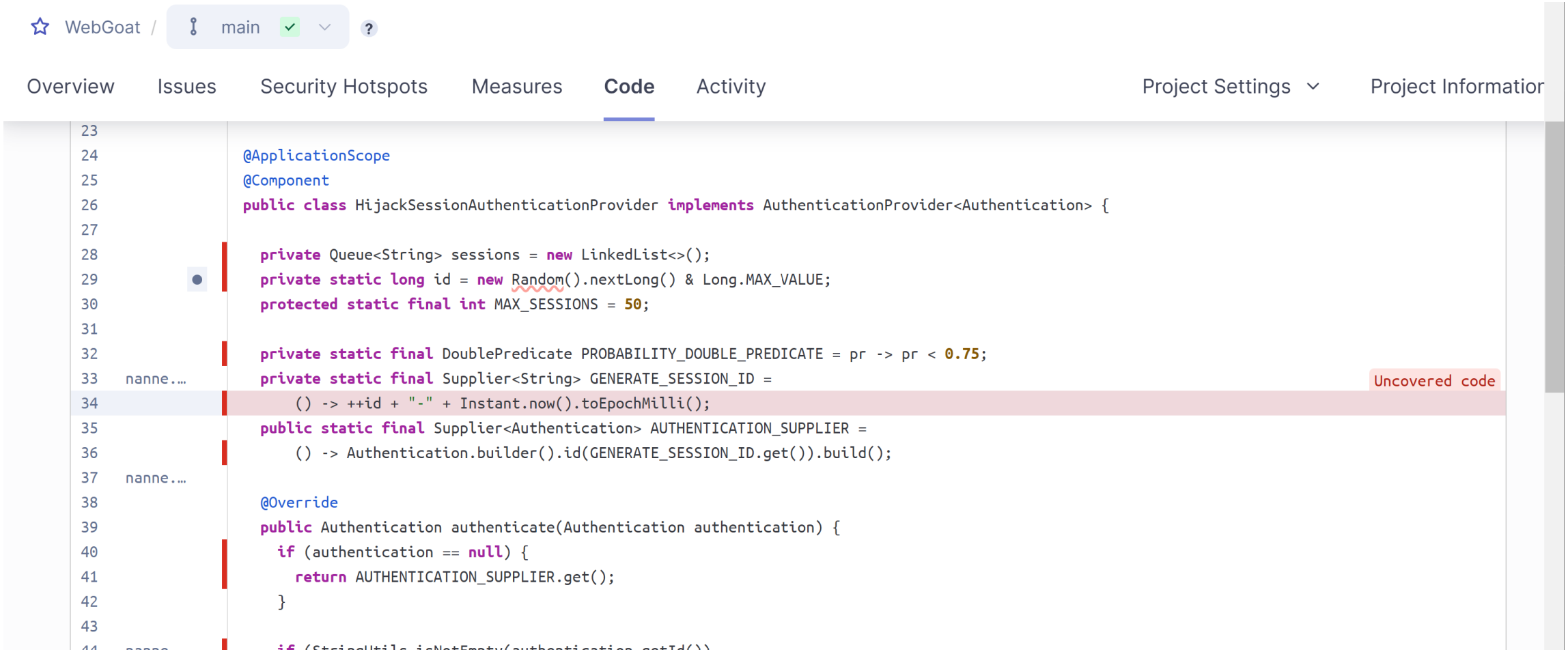
The `Random()` constructor tries to set the seed with a distinct value every time. However, there is no guarantee that the seed will be randomly or uniformly distributed. Some JDK will use the current time as seed, making the generated numbers not random.

This rule finds cases where a new `Random` is created each time a method is invoked.

Exceptions

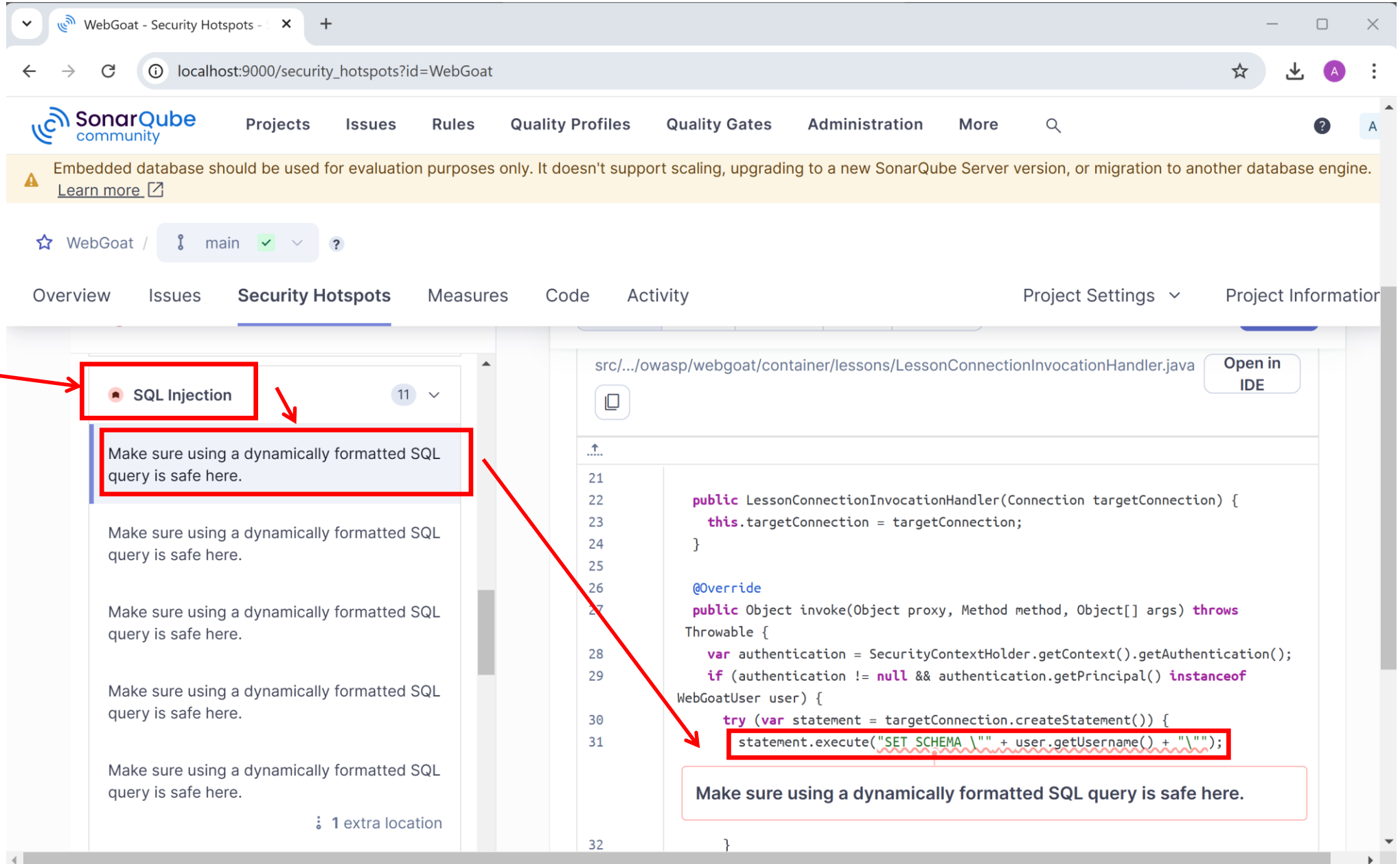
This rule doesn't apply to classes that use a `Random` in their constructors or the static `main` function and nowhere else.

Sonar focusses on "code quality" / "code pattern" and "test coverage"!! ... does not detect real bug



Back on exercise 2 ... "SQL Injection" analysis with Sonar

SQL Injections



More "complex" String variable detected

